



HARMONISED EUROPEAN STANDARD

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit <https://labs.etsi.org/rep/stan4cra/en-304-624> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

ETSI EN 304 624 V0.0.5 (2025-10)

CYBER; CRA; Essential cybersecurity requirements for Public Key Infrastructure and digital certificate issuance software

Should you need a step-by-step guide for drafting an ETSI deliverable, please consult the "[Principles for Drafting ETSI Deliverables]" (Principles for Drafting ETSI Deliverables) document. Otherwise you may contact us at edithelp@etsi.org.

Reference

DEN/CYBER-EUS-0015

Keywords

<keywords>

ETSI

650 Route des Lucioles

F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B

Association à but non lucratif enregistrée à la

Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or

other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without

79 limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out
80 of or related to the use of or inability to use the software.

81 ***Copyright Notification***

82 No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying
83 and microfilm except as authorized by written permission of ETSI. The content of the PDF version shall not be
84 modified without the written authorization of ETSI. The copyright and the foregoing restriction extend to reproduction
85 in all media.

86 © ETSI 2025.

87 All rights reserved

88

Contents

Table of Contents

89		
90		
91	•	Intellectual Property Rights
92	•	Foreword
93	•	Modal verbs terminology
94	•	Executive summary
95	•	Introduction
96	•	1 Scope
97	•	2 References
98	○	2.1 Normative references
99	○	2.2 Informative references
100	•	3 Definition of terms, symbols and abbreviations
101	○	3.1 Terms
102	○	3.2 Symbols
103	○	3.3 Abbreviations
104	•	4 PKI software contexts
105	○	4.1 Intended purpose of use
106	▪	4.2 Main functionalities
107	○	4.3 Architecture
108	○	4.4 Operationnal Environment
109	▪	4.4.1 Physical security
110	▪	4.4.2 Network security
111	▪	4.4.3 Users competences
112	○	4.5 Distribution of security functions
113	○	4.6 Users
114	○	4.7 Use cases
115	▪	4.7.1 Private PKI for none critical entities
116	○	4.7.2 Critical entities and public CA PKI software
117	▪	4.7.2.1 Use
118	▪	4.7.4 Operational environment
119	▪	4.7.3 C-ITS PKI
120	▪	4.7.4 Machine to Machine PKI
121	•	5 Requirements for PKI products

- 122 ○ [5.1 Auditing](#)
- 123 ○ [5.2 Secret management](#)
- 124 ○ [5.3 Certificate issuance](#)
- 125 ○ [5.4 Certificate status](#)
- 126 ○ [5.5 Certificate renewal](#)
- 127 ○ [5.6 Certificate re-key](#)
- 128 ○ [5.7 Certificate modification](#)
- 129 ○ [5.8 Certificate suspension and revocation](#)
- 130 ○ [5.9 Certificate status services](#)
- 131 • [6 Conformity Assessment](#)
- 132 ○ [6.1 Auditing](#)
- 133 ▪ [6.1.6 Conformity Assessment](#)
- 134 • [Annex A Mapping with essential requirements of the CRA](#)
- 135 • [Annex B Mappings](#)
- 136 ○ [B.1 Mapping of technical security requirements and assessment requirements](#)
- 137 ○ [B.2 Mapping of technical security requirements and risks factors](#)
- 138 ○ [B.3 Other relevant mappings, as appropriate](#)
- 139 • [Annex C Risk acceptance criteria and risk management methodology \(informative\) \(PT1 6.3\)](#)
- 140 ○ [C.1 Risk acceptance + risk management methodology](#)
- 141 ▪ [C.1.1 Rihs levels calculation](#)
- 142 ▪ [C.1.2 Likelihood risk factors](#)
- 143 ▪ [C.1.3 Impact risk factors](#)
- 144 ▪ [C.1.4 Risk acceptance threshold](#)
- 145 ○ [C.2 Risk Assessment](#)
- 146 ○ [C.2.1 ID Asset](#)
- 147 ○ [C.2.2 ID Threat](#)
- 148 ○ [C.2.3 Estimate Risks \(Risk factors\)](#)
- 149 ○ [C.2.4 Evaluate Risks](#)
- 150 • [Annex: Bibliography](#)
- 151 • [Annex : Change history](#)
- 152 • [History](#)

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [\[i.1\]](#) to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) [\[i.2\]](#).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table [...] confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

186

Modal verbs terminology

187

In the present document "**should**", "**should not**", "**may**", "**need not**", "**shall**", "**shall not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

188

189

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

Introduction

1 Scope

Editor's note: This section's is stable.

The present document specifies requirements and assessment criteria covering all elements defined in CRA Annex I Part 1 and Part 2 for Public key infrastructure (PKI) and digital certificate issuance software.

The present document covers the specification of Security Profiles (SP) for the main PKI use cases to demonstrate compliance with requirements in the EU Regulation 2024/2847 under the conditions identified in annex.

Different uses cases represent different deployment with different sets of architectures, functionalities and thus associated threats and risk. The document specifies requirements to cover or mitigate those risks in conformity with the CRA.

It covers main PKI able to support the management of public keys able to support authentication, encryption, integrity or non-repudiation services including public/open, private, C-ITS and machine-to-machine PKIs.

2 References

Editor's note: This section's structure is stable. More references are to be added.

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies. Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

- NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity. The following referenced documents are necessary for the application of the present document.
- [1] ITU-T X.509 (10/2019): "Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks"
 - NOTE: Identical text in the defining of public-key and attribute certificates is also available in ISO/IEC 9594-8 (paywall). Editor's - NOTE: the normal convention appears to be to refer to X.509 (as the original source) but in some cases references are cited as ITU-T X.509/ISO-IEC 9594-8.
- [2] "Standard Organization acronym" "document number" ("version number"): "Title".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

- NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] C(2025) 618 final: "COMMISSION IMPLEMENTING DECISION on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)"
- [i.2] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)"

3 Definition of terms, symbols and abbreviations

Editor's note: This section's structure is stable. Its content is to be further refined.

3.1 Terms

For the purposes of the present document, the [following] terms [given in ... and the following] apply:

Term	Definition
PKI Software	
Certificate	Public key of a user, together with some other information, rendered un-forgable by encipherment with the private key of the certification authority which issued it.
Certificate Policy (CP)	Named set of rules that indicates the applicability of a certificate to a particular community and/or class of application with common security requirements.
Certificate Revocation List (CRL)	signed list indicating a set of certificates that have been revoked by the certificate issuer.
Certification Authority (CA)	Authority trusted by one or more users to create and assign certificates.
Digital signature	Data appended to, or a cryptographic transformation of a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery e.g. by the recipient.
Registration Authority (RA)	entity that is responsible for identification and authentication of subjects of certificates mainly
Secure cryptographic device	Device which holds the user's private key, protects this key against compromise and performs signing or decryption functions on behalf of the user.
Critical entities	Critical entities as defined by Directive (EU) 2022/2557;

3.2 Symbols

For the purposes of the present document, the [following] symbols [given in ... and the following] apply:

3.3 Abbreviations

For the purposes of the present document, the [following] abbreviations apply:

AA	Authorization Authority (synonym to PCA)
AP	Access Point
AT	Authorization Ticket (synonym to PC)
CA	Certification Authority CRL Certification Authority Revocation List C-ITS Cooperative ITS
CP	Certificate Policy
CPOC	C-ITS-Point of Contact
CPS	Certification Practice Statement
CRL	Certificate Revocation List
DC	Distribution Center
EA	Enrolment Authority (similar to LTCA)
EC	Enrolment Credential (similar to LTC)
HSM	Hardware Security Module
ITS	Intelligent Transport System
MA	Misbehaviour Authority #unsure whether this is the correct term (GDC)
OCSF	Online Certificate Status Protocol

259	PKC	Public Key Certificate
260	PKI	Public Key Infrastructure
261	RA	Registration Authority
262	RCA	Root Certificate Authority
263	SP	Security Profile
264	TLM	Trust List Manager
265	TSL	Trust-service Status List
266	TSP	Trust Service Provider

4 PKI software contexts

- NOTE: This section's structure is built upon CEN/CLC JTC13 PT01's deliverable and might require restructuring based on its progress.

4.1 Intended purpose of use

Editor's note: This section's is stable.

The present clause describes product contexts for products with digital elements used as part of a public key infrastructure (PKI) that manage the validation, creation, issuance, distribution, status publication, renewal or revocation of digital certificates, or the generation, storage, escrow, exchange, destruction or rotation of cryptographic keys associated with such digital certificates.

4.2 Main functionalities

Editor's note: This section's structur is stable. The content is not stable.

Products with digital elements used as part of a public key cryptography scheme to manage asymmetric cryptographic keys and digital certificates, including their creation, issuance, distribution, validation, renewal, storage or revocation. This category includes but is not limited to key management systems, digital certificate management systems and online certificate status protocol responders

PKI products support one or more of the following component services (see ETSI EN 319 411-1):

- F.Registration service:** registers and receives certificate requests from subscribers; verifies the identity and, if applicable, attributes of a subject; and passes verified certificate requests to the certificate generation service.

NOTE 1: This service includes proof of possession of, or control over, subject private keys when these are not generated by the certificate generation service.

NOTE 2: If subject private keys are generated and stored by the certificate generation service to allow key recovery, this service receives and verifies key recovery requests from subscribers.

- F.Certificate generation service:** generates and manages the CA keys; creates and signs subject certificates based on the identity and other attributes verified by the registration service; and passes the signed subject certificates to the dissemination service.

NOTE 3: This service can use a secure cryptographic device to generate, store and use the CA keys.

NOTE 4: This service can include generation of subject keys and, if used for decryption, storage of subject private keys to allow key recovery.

- F.Dissemination service:** distributes signed certificates to subscribers; and, if applicable, stores and makes them available to relying parties.

NOTE 5: This service can also distribute subject private keys to subscribers if the subject keys are generated by the certificate generation service.

- F.Revocation management service:** processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service.

- F.Certificate status service:** provides certificate revocation status information to relying parties.

Each component service shall require configuration and maintenance by system administrators.

PKI products also usually support:

- F.Logging of security events:** for example, account access attempts, product configuration changes, and system warnings or errors.

They shall typically support some logging of events relevant to each of the component service it provides. For example:

- Registration service events such as certificate requests and approvals.
- Certificate generation service events such as subject key generation and certificate signing operations.

PKI products also support:

- **F.User accounts management:**
 - **System administrator account:** authorised to install, configure and update the product.
 - **System operator account:** authorised to operate the PKI services.

4.3 Architecture

Editor's note: This section's structur is stable. The content is not stable.

Figure 4.1 gives a high-level overview of a generic and illustrative PKI architecture.

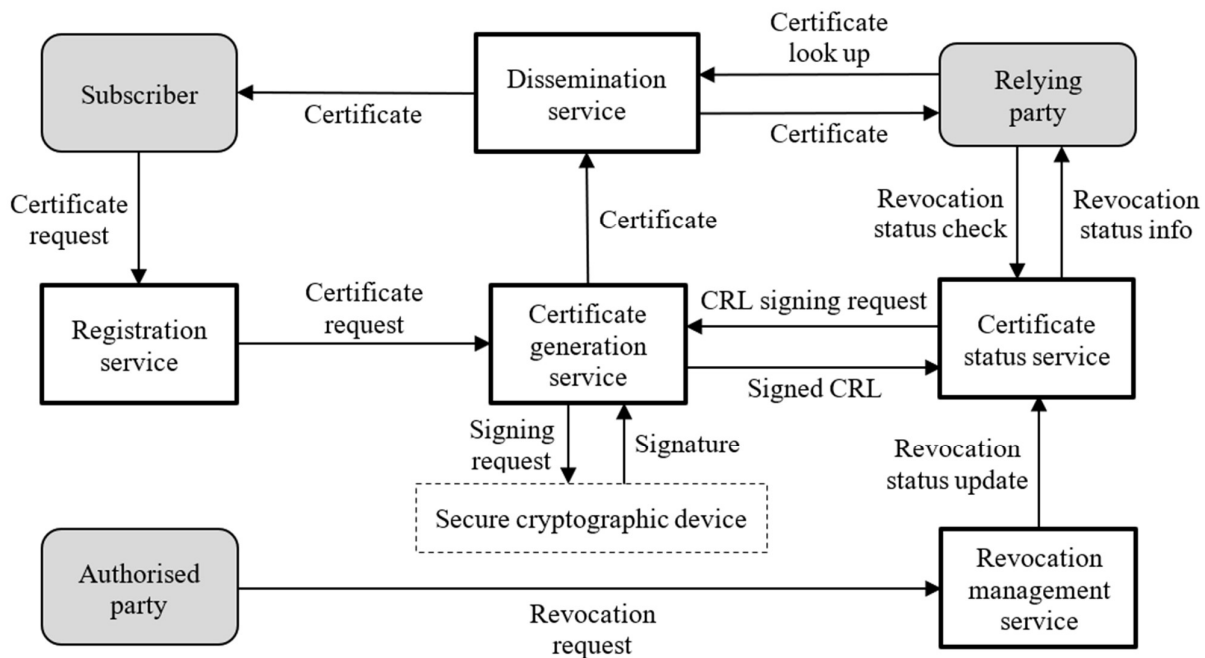


Figure 4.1-1: PKI diagram

4.4 Operationnal Environment

Editor's note: This section's structur is stable. The content is not stable.

The enterprise shall have a production system for issuing certificates and can be expected to have a separate test system for checking configuration changes and software updates before they are deployed.

The PKI software shall be deployed on servers within the enterprise's server rooms or data centre, or on a platform hosted by the enterprise's cloud service provider.

NOTE 1: PKI-as-a-service and software-as-a-service are out of scope of the present document. #(GDC) This has already been said in the Scope section; no need to repeat.

If the certificate generation service in the production system uses a secure cryptographic device to manage the CA keys, this can be a physical device located in the enterprise's data centre or a virtual device hosted by the enterprise's cloud service provider.

NOTE 2: Security requirements for secure cryptographic devices are out of scope of the present document.

4.4.1 Physical security

An enterprise server room or data centre shall have some physical access controls.

A cloud service provider shall have strong physical security measures in place, but the servers hosting the PKI software shall not be physically separated from other infrastructure.

4.4.2 Network security

The enterprise shall implement security controls such as firewalls on the edge of their network.

The enterprise shall implement internal network access controls that limit access to systems hosting the PKI software to authorised users.

The enterprise shall deploy malware detection and removal software on their systems.

4.4.3 Users competences

The enterprise shall employ competent system administrators to install, configure and manage the software.

However, system operators might have limited experience running critical component services and might have only received basic training in cybersecurity or data protection.

4.5 Distribution of security functions

Editor's note: This section's is still to be done.

4.6 Users

Editor's note: This section's structur is stable. The content has not been reviewed.

PKI products users' roles and responsibilities can be:

PKI Administrator

- **Role:** Authorized to **install, configure, and maintain the PKI produt**, ensuring its proper operation and security.
- **Responsibilities:**
 - Establish and manage **user accounts and access controls**.
 - Set up and maintain **audit and logging configurations**.
 - Generate and manage **cryptographic keys and components** (e.g., CA keys, HSM keys).
 - Ensure compliance with **organizational policies and regulatory requirements**.
 - Troubleshoot and resolve **technical issues** related to the PKI infrastructure.

PKI Operator

- **Role:** Authorized to **perform operational tasks** to ensure the availability and integrity of the PKI system.
- **Responsibilities:**
 - Execute **system backups and recovery procedures** to prevent data loss.
 - Monitor **PKI system health and performance**.

- 366 ○ Manage **routine operational tasks**, such as certificate issuance workflows.
- 367 ○ Ensure **high availability** of PKI services.
- 368 ○ Assist in **disaster recovery and contingency planning**.

369 **PKI Officer (or Registration Authority Officer)**

- 370 • **Role:** Authorized to **manage certificate lifecycle operations**, including approvals and revocations.
- 371 • **Responsibilities:**
 - 372 ○ Configure **PKI profiles, policies, and security parameters**.
 - 373 ○ Review and **approve or reject certificate requests** based on policy compliance.
 - 374 ○ Initiate and manage **certificate revocation** (e.g., due to compromise, expiration, or policy violations).
 - 375 ○ Verify the **identity and authenticity** of certificate applicants.
 - 376 ○ Ensure that **certificate issuance and revocation processes** align with organizational policies.
 - 377 ○ Collaborate with the **PKI Administrator** to maintain the integrity of the PKI system.

378 **PKI Auditor**

- 379 • **Role:** Authorized to **monitor and review PKI operations** to ensure compliance and security.
- 380 • **Responsibilities:**
 - 381 ○ Access and **review audit logs** to detect anomalies or policy violations.
 - 382 ○ Verify that **PKI operations** comply with organizational policies and regulatory standards.
 - 383 ○ Generate **audit reports** for internal or external review.
 - 384 ○ Identify and report **potential security risks or non-compliance issues**.
 - 385 ○ Ensure **transparency and accountability** in PKI operations.

386 **PKI End User**

- 387 • **Role:** Individuals or systems that **request certificates** or **check certificate status** for authentication,
388 encryption, or digital signing purposes.
- 389 • **Responsibilities:**
 - 390 ○ Submit **certificate signing requests (CSRs)** to the PKI system.
 - 391 ○ Provide **accurate identification information** as required by the PKI policy.
 - 392 ○ Verify the **status of certificates** (e.g., validity, revocation status) using protocols like OCSP (Online
393 Certificate Status Protocol) or CRLs (Certificate Revocation Lists).
 - 394 ○ Use **issued certificates** in compliance with organizational policies and security best practices.
 - 395 ○ Report **lost, compromised, or suspicious certificates** to the PKI Officer or Administrator.
 - 396 ○ Follow **certificate renewal procedures** to maintain uninterrupted access to secure services.

397 **4.7 Use cases**

398 PKIs can take many forms and this standard doesn't aim to cover all possible PKI's service implementations and the
399 associated PKI product required for these implementations. The uses cases considered are:

- 400 • Private PKI for none critical sectors small or medium enterprise as defined by NIS2 directive

- Private PKI for large enterprise or critical sectors enterprise as defined by NIS2 directive
- Open or public PKI for Certificate Authorities (CA)
- C-ITS PKI
- Machine to machine

Security Profiles are defined for those specific use cases. Those profiles are the combination of the security and assessment requirements applicable to each use cases. In section 5 requirements are associated to an applicability conditions which depends on the use cases risks analysis as defined in Annex C.

Products not directly matching those use cases have to refine one of those profile to adapt them to there own risk analysis.

In the **Private PKI product context**, a single instance of a self-contained PKI product shall typically support all of the required PKI functionality.

However, some component PKI services might not be necessary or could be supported through generic enterprise products and services.

EXAMPLE 1: The registration service is not needed as subscriber enrollment and certificate request approvals are handled through normal enterprise on-boarding and account management processes.

EXAMPLE 2: The revocation managment and certificate status services are not needed as compromised certificates can be mitigate through normal enterprise account management and off-boarding processes.

EXAMPLE 3: The dissemination service is not needed as an enterprise directory service can be used to store and distribute certificates.

4.7.1 Private PKI for none critical entities

Editor's note: This section's structur is stable. The content is not stable.

4.7.1.1 Assets

4.7.1.1.1 System administration

Table 5.1 provides a list of system administration assets for the PKI product.

Table 4.7.1.1.1-1: System administration assets

Asset	Description
SYS01: System configuration data	Includes settings for software updates, event logging, component services, and the secure cryptographic device, if applicable
SYS02: User account data	Includes user authentication credentials and access rights
SYS03: Event log data	Includes system administration and component service event data
SYS11: System configuration management function	Used to change system configuration settings and reset to default values
SYS12: User account management function	Used to create and delete accounts, and change authentication credentials and access rights
SYS13: Event log management function	Used to view event log data
SYS14: Software update function	Used to manage installation of software updates
SYS21: Remote administration interface	E.g., remotely accessible web portal

Asset	Description
SYS22: Local administration interface	E.g., locally accessible command line interface

4.7.1.1.2 Registration service

Table 5.2 provides a list of assets for a PKI product that supports registration services.

Table 4.7.1.1.2-1: Registration assets

Asset	Description
REG01.Subscriber data	Includes subscriber identity and contact information
REG02.Certificate request	Subject certificate signing request
REG11.Subscriber management function	Used to register subscribers and change subscriber details
REG12.Certificate request management function	Used to approve or reject subject certificate requests
REG21.Registration user interface	E.g., remotely accessible web portal
REG22.Certificate request API	E.g., remotely accessible logical interface

If the PKI product does not provide support for subscriber management as part of its registration services, then the subscriber data (REG01) and subscriber management function (REG11) assets shall not be present.

4.7.1.1.3 Certificate generation service

Table 5.3 provides a list of assets for a PKI product that supports certificate generation services.

Table 4.7.1.1.3-1: Certificate generation assets

Asset	Description
GEN01.CA key data	CA private signing keys
GEN02.Subject key data	Subject private decryption keys
GEN11.Key management function	Used to manage CA and subject private keys
GEN12.Certificate generation function	Used for certificate and CRL signing operations
GEN21.Certificate generation user interface	E.g., remotely accessible web portal or locally accessible command line interface
GEN22.Secure cryptographic device interface	Logical interface for the secure cryptographic device

If the PKI product supports the use of a secure cryptographic device, then the CA key data (GEN01) can be stored on the secure device.

If the PKI product does not support the use of a secure cryptographic device, then the secure cryptographic device interface (GEN22) shall not be present.

If the PKI product does not support the use of subject key generation or subject key recovery, then the subject key data (GEN02) shall not be present and the key management function (GEN11) shall only be used to manage CA private keys.

If the PKI product does not support registration services, then certificate requests can either be submitted directly via the certificate generation service user interface (GEN21) or via a related logical interface.

4.7.1.1.4 Dissemination service

Table 5.4 provides a list of assets for a PKI product that supports dissemination services.

Table 4.7.1.1.4-1: Dissemination assets

Asset	Description
DIS01.Certificate store data	Issued subject certificates and related information
DIS11.Certificate store management function	Used to manage certificates in the certificate store
DIS12.Certificate store look-up function	Used to handle requests for certificates from relying parties
DIS21.Dissemination user interface	E.g., remotely accessible web portal
DIS22.Subscriber dissemination interface	E.g., email client interface
DIS23.Relying party look-up interface	E.g., remotely accessible logical interface

If the PKI product does not support dissemination services, then the dissemination assets shall be replaced by a logical interface to a third-party enterprise directory service.

4.7.1.1.5 Revocation management service

Table 4.7.1.1.5-1 provides a list of assets for a PKI product that supports revocation management services.

Table 4.7.1.1.5-1: Revocation management assets

Asset	Description
REV01.Revocation request	Request to revoke an issued subject certificate
REV11.Revocation management function	Used to approve or reject revocation requests
REV21.Revocation management user interface	E.g., remotely accessible web portal

The PKI product can support limited revocation management services even if it does not support a certificate status service. In such cases, the revocation management function (REV11) and user interface (REV21) assets can be considered part of the corresponding certificate generation function (GEN12) and user interface (GEN21) assets.

4.7.1.1.6 Certificate status service

Table 4.7.1.1.6-1 provides a list of assets for a PKI product that supports certificate status services.

Table 4.7.1.1.6-1: Certificate status assets

Asset	Description
STA01.Certificate status data	Revocation status of issued certificates
STA11.Certificate status management function	Used to update certificate statuses and issue CRLs
STA21.Certificate status user interface	E.g., remotely accessible web portal
STA22.Relying party certificate status interface	E.g., remotely accessible logical interface

4.7.1.2 Threats

4.7.1.2.1 System administration

Table 4.7.1.2.1-1: System administration threats

Threat	Asset	Property
T_SYS01.Exploiting insecure settings in default system configuration data	SYS01	Secure by Default
T_SYS02.Modifying settings in unprotected system configuration data	SYS01	Integrity

Threat	Asset	Property
T_SYS03.Disclosing sensitive parameters in unprotected system configuration data	SYS01	Confidentiality
T_SYS04.Exploiting insecure user authentication credentials or access rights in default user account data	SYS02	Secure by Default
T_SYS05.Modifying user authentication credentials or access rights in unprotected user account data	SYS02	Integrity
T_SYS06.Disclosing user authentication credentials in unprotected user account data	SYS02	Confidentiality
T_SYS07.Modifying or deleting events in unprotected event log data	SYS03	Integrity, Non-repudiation
T_SYS08.Accessing settings or sensitive parameters via an unprotected system configuration management function	SYS11	Authorisation
T_SYS09.Accessing user authentication credentials or access rights via an unprotected user account management function	SYS12	Authorisation
T_SYS10.Accessing event logs via an unprotected event log management function	SYS13	Authorisation
T_SYS11.Disabling or rolling back software updates via an unprotected software update function	SYS14	Authorisation
T_SYS12.Modifying settings in configuration data transferred via an unprotected remote administration interface	SYS21	Integrity
T_SYS13.Disclosing sensitive parameters in configuration data transferred via an unprotected remote administration interface	SYS21	Confidentiality
T_SYS14.Accessing system administration functions via an unprotected remote administration interface	SYS21	Authentication
T_SYS15.Denying system administrator access via an unprotected remote administration interface	SYS21	Availability
T_SYS16.Accessing system administration functions via an unprotected local administration interface	SYS22	Authentication

4.7.1.2.2 Registration service

Table 4.7.1.2.2-1: Registration threats

Threat	Asset	Property
T_REG01.Modifying information in unprotected subscriber data	REG01	Integrity
T_REG02.Disclosing sensitive information in unprotected subscriber data	REG01	Confidentiality
T_REG03.Modifying an unprotected certificate request	REG02	Integrity
T_REG04.Accessing information via an unprotected subscriber management function	REG11	Authorisation
T_REG05.Approving a certificate request via an unprotected certificate request management function	REG12	Authorisation
T_REG06.Modifying information in subscriber data or certificate requests transferred via an unprotected registration user interface	REG21	Integrity

Threat	Asset	Property
T_REG07.Disclosing sensitive information in subscriber data transferred via an unprotected registration user interface	REG21	Confidentiality
T_REG08.Accessing registration service functions via an unprotected registration user interface	REG21	Authentication
T_REG09.Denying system operator access via an unprotected registration user interface	REG21	Availability
T_REG10.Denying subscriber access via an unprotected certificate request API	REG22	Availability

If the PKI product does not provide support for subscriber management as part of its registration services, then the threats to the subscriber data (T_REG01 and T_REG02) and subscriber management function (T_REG04) are not present.

4.7.1.2.3 Certificate generation service

Table 4.7.1.2.3-1: Certificate generation threats

Threat	Asset	Property
T_GEN01.Modifying CA private keys in unprotected CA key data	GEN01	Integrity
T_GEN02.Disclosing CA private keys in unprotected CA key data	GEN01	Confidentiality
T_GEN03.Deleting CA private keys in unprotected CA key data	GEN01	Availability
T_GEN04.Modifying subject private keys in unprotected subject key data	GEN02	Integrity
T_GEN05.Disclosing subject private keys in unprotected subject key data	GEN02	Confidentiality
T_GEN06.Deleting subject private keys in unprotected subject key data	GEN02	Availability
T_GEN07.Accessing CA or subject private keys via an unprotected key management function	GEN11	Authorisation
T_GEN08.Accessing signing operations via an unprotected certificate generation function	GEN12	Authorisation
T_GEN09.Accessing certificate generation functions via an unprotected certificate generation user interface	GEN21	Authentication
T_GEN10.Denying system operator access via an unprotected certificate generation user interface	GEN21	Availability
T_GEN11.Modifying information transferred between the product and a secure cryptographic device via an unprotected secure cryptographic device API	GEN22	Integrity
T_GEN12.Disclosing sensitive information transferred between the product and a secure cryptographic device via an unprotected secure cryptographic device API	GEN22	Confidentiality
T_GEN13.Disrupting the operation of a secure cryptographic device via requests from the product over the secure cryptographic device API	GEN22	Impact

NOTE 1: Accessing the functionality of the secure cryptographic device via an API that does not provide authentication or authorisation is a threat to the secure cryptographic device, not to the cyber security of the PKI product.

NOTE 2: Denying access to the secure cryptographic device via an API that does not provide availability is a threat to the secure cryptographic device, not to the cyber security of the PKI product. However, if the operation of the secure cryptographic device is impacted by, for example, the number of signing requests from the PKI product then this is relevant to the cyber security of the PKI product as it is not minimising its impact on other devices or networks (T_GEN13).

If the PKI product does not support the use of a secure cryptographic device, then the threats to the secure cryptographic device interface (T_GEN11 and T_GEN12) shall not be present.

If the product does not support subject key generation or key recovery, the threats to the subject key data (T_GEN04, T_GEN05 and T_GEN06) shall not be present and the threat to the key management function (T_GEN07) shall only cover the CA key data.

4.7.1.2.4 Dissemination service

Table 4.7.1.2.4-1: Dissemination threats

Threat	Asset	Property
T_DIS01.Modifying certificates in unprotected certificate store data	DIS01	Integrity
T_DIS02.Accessing certificate store data via an unprotected certificate store management function	DIS11	Authorisation
T_DIS03.Accessing dissemination service functions via an unprotected dissemination user interface	DIS21	Authentication
T_DIS04.Denying system operator access to via an unprotected dissemination user interface	DIS21	Availability
T_DIS05.Modifying certificates transferred via an unprotected subscriber dissemination interface	DIS22	Integrity
T_DIS06.Disclosing subject private keys transferred via an unprotected subscriber dissemination interface	DIS22	Confidentiality
T_DIS07.Modifying certificate look-up responses via an unprotected relying party look-up interface	DIS23	Integrity
T_DIS08.Denying relying party access to an unprotected relying party look-up interface	DIS23	Availability

If the PKI product does not support dissemination services and provides a logical interface to a third-party directory service, then the threats to the subscriber dissemination interface (T_DIS05 and T_DIS06) apply to the directory service interface instead.

4.7.1.2.5 Revocation management service

Table 4.7.1.2.5-1: Revocation management threats

Threat	Asset	Property
T_REV01.Modifying information in an unprotected revocation request	REV01	Integrity
T_REV02.Disclosing sensitive information in an unprotected revocation request	REV01	Confidentiality
T_REV03.Approving or denying revocation requests via an unprotected revocation management function	REV11	Authorisation
T_REV04.Modifying information transferred via an unprotected revocation management user interface	REV21	Integrity
T_REV05.Disclosing sensitive information transferred via an unprotected revocation management user interface	REV21	Confidentiality
T_REV06.Accessing revocation management functions via an unprotected revocation management user interface	REV21	Authentication
T_REV07.Denying system operator access to an unprotected revocation management user interface	REV21	Availability

The PKI product can support limited revocation management services even if it does not support a certificate status service. In such cases, the threats to the revocation management function (T_REV03) and user interface (T_REV04, T_REV05, T_REV06 and T_REV07) apply to the corresponding certificate generation function and user interface.

4.7.1.2.6 Certificate status service

Table 4.7.1.2.6-1: Certificate status threats

Threat	Asset	Property
T_STA01.Modifying certificate revocation statuses in unprotected certificate status data	STA01	Integrity, Non-repudiation
T_STA02.Accessing certificate revocation statuses via an unprotected certificate status management function	STA11	Authorisation
T_STA03.Accessing certificate status functions via an unprotected certificate status user interface	STA21	Authentication
T_STA04.Denying system operator access to an unprotected certificate status user interface	STA21	Availability
T_STA05.Modifying certificate revocation statuses transferred via an unprotected relying party certificate status interface	STA22	Integrity, Non-repudiation
T_STA06.Denying relying party access to an unprotected relying party certificate status interface	STA22	Availability

4.7.2 Critical entities and public CA PKI software

Editor's note: This section's structure is stable. The content is not stable.

4.7.2.1 Use

The reasonably foreseeable use of the PKI product is to support certification services provided within a large enterprise or provided by a CA to the public, and where a compromise carries a significant risk of impact to the security of other products, networks or services, or to the health, security or safety of the public.

EXAMPLE 1: Software used to issue certificates for public web sites.

EXAMPLE 2: Software used to issue certificates for mobile network infrastructure.

EXAMPLE 3: Software used to issue certificates for central government public administration organisations.

4.7.2.2 Functionality

4.7.2.2.1 Services

The PKI product shall support one or more of the following component services (see ETSI EN 319 411-1):

- **Registration service:** as described in clause 4.2.2.1.

EXAMPLE 1: This service verifies ownership of the domain in requests for public web site certificates

- **Certificate generation service:** as described in clause 4.2.2.1.

NOTE 1: The certificate profile used in certificate creation, including the signature algorithm, certificate lifetime and key usage restrictions, is determined by the CA's Certificate Policy (CP) or an equivalent document.

NOTE 2: This service shall typically use a secure cryptographic device to generate, store and use the CA keys.

- **Dissemination service:** as described in clause 4.2.2.1.

NOTE 3: This service can also make the CA's terms and conditions, policy and practice information available to subscribers and relying parties.

- **Revocation management service:** as described in clause 4.2.2.1.

EXAMPLE 2: This service verifies that revocation requests are submitted by authorised parties.

EXAMPLE 3: This service obtains confirmation from the subscriber if a compromise is reported by a third party.

- **Certificate status service:** as described in clause 4.2.2.1.

Each component service shall require configuration and maintenance by system administrators.

4.7.2.2.2 Logging

The PKI product shall support logging of security events; for example, account access attempts, product configuration changes, and system warnings or errors.

The PKI product shall support logging of events relevant to each of the component service it provides. For example:

- Registration service events such as certificate requests and approvals.
- Certificate generation service events such as subject key generation and certificate signing operations.
- Revocation management service events such as revocation requests and results.

4.7.2.2.3 Accounts

In the large enterprise and public PKI product context, the product shall support at least the following user accounts:

- **System administrator account:** authorised to install, configure and update the product.
- **System operator account:** authorised to operate the PKI services.
- NOTE: This might consist of separate registration service operator, certificate generation service operator and revocation service operator accounts.
- **System auditor account:** authorised to view audit logs and other system data.

4.7.2.3 Architecture

Figure 4.1 in clause 4.2.3 gives a high-level example of a PKI architecture.

A large enterprise or public PKI might include multiple instances of some component services.

EXAMPLE 1: Multiple registration services connected to a single certificate generation service for scalability.

EXAMPLE 2: Multiple certificate generation services for availability and disaster recovery.

In some use cases, the PKI might not include some component services

EXAMPLE 3: Revocation management and certificate status services might not be needed if the CA only issues short-lived certificates that are not intended to be revoked.

PKI products intended for large enterprise or public PKI use can be designed to be modular so that each instance of the product provides a single component service with multiple instances of the product networked together to provide the full CA functionality.

The PKI can also be designed to use generic enterprise products to support the functionality of some component services.

EXAMPLE 4: A third-party database might be used to store and manage subscriber and certificate data.

EXAMPLE 5: A third-party logging service might be used to store and manage event logs.

4.7.4 Operational environment

4.7.2.4.1 Deployment

The large enterprise or public CA shall have a production system for issuing certificates and can be expected to have separate development or test systems for checking configuration changes and software updates before they are deployed.

The PKI software shall typically be deployed on servers within the CA's data centre, but less critical component services can be deployed on a platform hosted by a cloud service provider.

NOTE 1: PKI-as-a-service and software-as-a-service are out of scope of the present document. # (GDC) This note is redundant

The certificate generation service in the production system shall use a secure cryptographic device to manage the CA keys and, if required, generate subject keys. This shall likely be a physical device located in the enterprise's data centre.

NOTE 2: Security requirements for secure cryptographic devices are out of scope of the present document.

4.7.2.4.2 Physical security

The CA shall locate production infrastructure supporting security critical component services such as certificate generation in a secure perimeter with physical protection against intrusion and physical controls limiting access to authorised personnel.

The CA shall implement controls to prevent the loss, theft or compromise of its equipment, media, and data.

The CA shall implement measures to prevent a compromise or interruption of its services due to an electricity, network, or other utility failure.

4.7.2.4.3 Network security

The CA shall implement change control procedures for any software updates and configuration changes.

572 The CA shall deploy security updates in a reasonable time, unless they introduce additional vulnerabilities or system
 573 instabilities, and review and verify configuration settings regularly.

574 The CA shall implement security controls such as firewalls and intrusion detection and prevention systems on its
 575 networks, deploy malware detection and removal software on its infrastructure, and undergo regular vulnerability scans
 576 and penetration tests.

577 The CA shall locate security-critical component services such as certificate generation in one or more secure network
 578 zones, and restrict access and communication between zones.

579 The CA shall have a dedicated network for the administration and operation of its production system that is logically
 580 separated from its other systems.

581 The CA shall block protocols and disable accesses that are not needed for PKI operations.

582 4.7.2.4.3 Users competences

583 A large enterprise or public CA shall employ staff who have the necessary expertise and experience for their roles,
 584 including an understanding of cybersecurity and data protection where relevant.

585 The CA shall provide staff with regular training on current security practices and apply appropriate disciplinary
 586 sanctions to staff who violate the CA's policies or procedures.

587 The CA shall perform additional checks on staff employed in trusted roles such as system administrators, system
 588 operators and system auditors, and wait for the checks to be completed before giving access to the trusted service.

589 The CA shall enforce separation between trusted roles with conflicting responsibilities such as system operators and
 590 system auditors.

591 4.7.3 C-ITS PKI

592 *Editor's note: This section's structure is stable. The content is not stable.*

593 A Public Key Infrastructure (PKI) dedicated to Communicating Intelligent Transport Systems (C-ITS) is used to
 594 manage ITS related certificates to enable deployment of security functions over the different components of ITS
 595 systems, mainly signature and encryption of ITS messages. The PKI is responsible for the issuance, revocation, and
 596 overall management of certificates and certificate status information. The PKI architecture and its functionalities
 597 considered here are the one standardized by the ETSI in ETSI TS 102 940 and ETSI TS 102 941. The C-ITS PKI shall
 598 provide the different services required by the RCA, EC and AA roles defined by the European C-ITS trust model. In the
 599 figure we also identify the role of a Misbehaviour Authority (MA): entity responsible to receive misbehaviour reports
 600 coming from ITS-S identifying other misbehaving ITS and emits action requests to the other C-ITS PKI authorities to

react to misbehaving behaviour of ITS-S. The current PP does not define requirement for the MA services since the MA communication and services are not yet fully define and standardized. However the PP should be updated when it is.

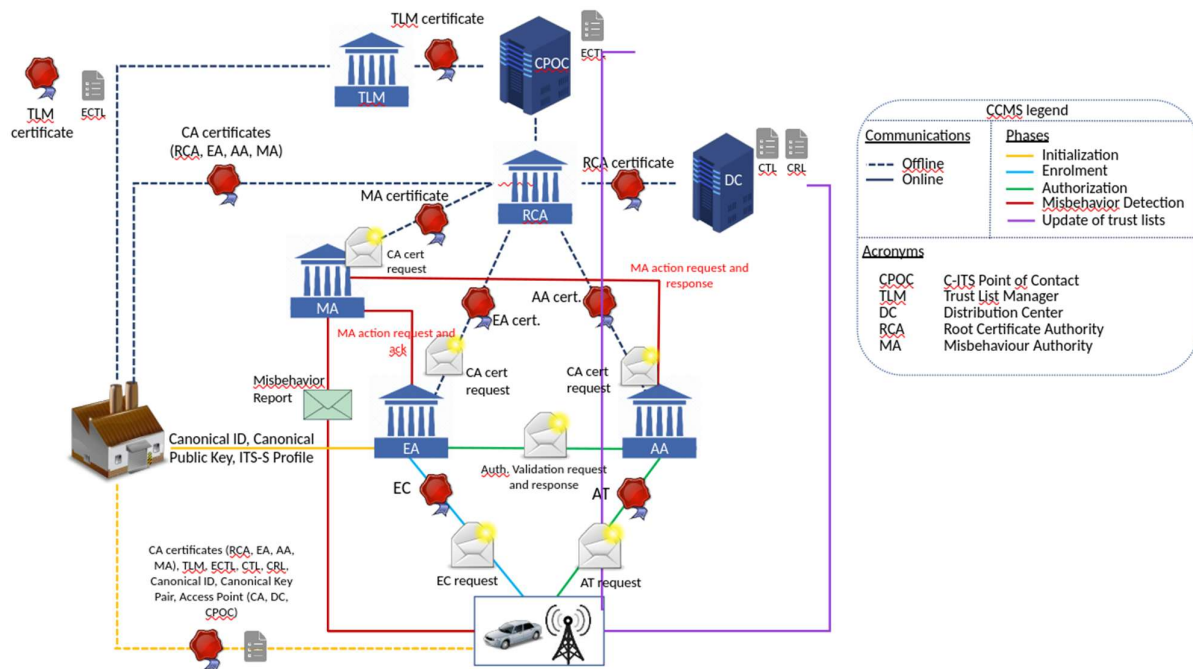


Figure 4.7.3-1: C-ITS_PKI_Architecture

4.7.3.1 Assets

Name	Description	Security needs
Keys		
A_Canonical Public Key	Public key generated by ITS-Station and used by the EA to verify EC request signature.	Integrity
A_Data encryption key	AES key used to encrypt requests and responses messages data.	Integrity, confidentiality
A_CA private keys	Private keys corresponding to the public keys contained in CA certificates issued by the PKI system. These keys are used for signature/encryption mechanisms.	Confidentiality, integrity
Certificates		
A_CA Certificates	This includes the root CA self-signed, EA, AA, and MA certificates generated by the root CA.	Availability
A_Enrolment Credential (EC)	EC is a certificate that contains a unique name, a public key, and other attributes.	Integrity
A_Authorization Ticket (AT)	AT is a pseudonym certificate that does not contain any identification information but public key(s) and other attributes.	Integrity
A_TLM certificate	Self-signed certificate managed by EU	Availability
Station registration data		
A_Canonical ID	This information is stored at initial registration of the ITS station under the responsibility of the manufacturer. The canonical ID	Integrity, confidentiality

Name	Description	Security needs
	shall contain a substring identifying the manufacturer or operator to make uniqueness of this identifier possible.	
A_ITS-S Profile	The profile information for the ITS-S that may contain an initial list of maximum appPermissions (ITS-AIDs with SSPs), region restrictions, etc., which may be modified over time.	Integrity
A_Tag	HMAC-SHA 256 of the keys to be certified.	Confidentiality, integrity
A_HMAC key	Key used to compute Tags sent with AT requests.	Confidentiality, integrity, availability
CA Network addresses		
A_CA Network addresses	URL used to communicate with the CA.	Integrity, availability
A_DC network address	URL used to communicate with the DC.	Integrity, availability
A_CPOC Network address	URL used to communicate with the DC.	Integrity, availability
Policies		
A_Certificate Policy configuration data	Configuration data defining the role and duties of the PKI entities, including definition of parameters for: issuance, publication, archiving, revocation, renewal. This includes the certificate profiles.	Integrity, availability
Trust lists		
A_CRL	This list contains all information about revoked entities and needs to be protected from any malicious change. We need to assure the integrity of this list as defined in (1).	Integrity, availability
A_CTL	This list contains all information about trusted entity certificates (CA), using the format and properties as defined in (1).	Integrity, availability
A_ECTL	This list contains all information about root CA certificates (certificates, URL to access the CPOC, ...) as defined by (1).	Integrity, availability
PKI services		
A_Software/Execution of the software	Correct execution of the TOE function to provide the correct services.	Integrity
Misbehavior detection		
A_Misbehaviour Report (MR)	Reports sent by the ITS-S to the MA to provide information regarding a possible misbehaving ITS-S (8).	Integrity, availability

606 4.7.3.2 Essential Functions

Function	description	Associated user/role
Access audit records	The C-ITS PKI shall provide the Auditors the capability to access the audit traces generated by the C-ITS PKI.	Auditor

Function	description	Associated user/role
Configure the audit mechanism	The C-ITS PKI shall provide the following audit mechanisms configuration mechanisms: Define/modify audit records format, Definition of event types generating audit traces, Setting of retention period parameter for audit records requiring extended retention	Configuration and management administrator
Configure and manage certificate profiles	The C-ITS PKI shall provide the following configuration capabilities for all certificates profiles: Define 'cracId' value to be defined by default to 000000'H, Define crlSeries value to be set by default to 0'D, Define the component 'assuranceLevel' of type SubjectAssurance as defined in (IEEE, 2016-03-01), present or absent according to the specification of certificate profiles defined in section 7.2 of (ETSI) (set default value)	Configuration and management administrator
	The C-ITS PKI shall provide the following configuration capabilities for Root CA certificate profiles: Define validity period, Define 'region' of type GeographicRegion as defined in (IEEE, 2016-03-01), including 'present' or 'absence' parameter, Define 'appPermissions' which contains the ITS-AID for the CRL, CTLs and contain the ITS-AID for the CTL as assigned in (ETSI)	Officer
	The C-ITS PKI shall provide the following configuration capabilities for EC profiles: 'region' of type GeographicRegion as defined in (IEEE, 2016-03-01), present or absence, The 'toBeSigned' component CertificateId shall be set to the choice name and shall contain a unique name associated to the enrolment credential -> default value, 'appPermissions' shall be used to indicate message signing permissions, i.e. permissions to sign a certificate request message contained in a EtsiTs103097Data as defined in (ETSI)	Configuration and management administrator
	The C-ITS PKI shall provide the following configuration capabilities to Subordinate certification authority certificates (EA / AA) for certificates profiles: 'region' of type GeographicRegion as defined by (IEEE, 2016-03-01), present or absence, 'appPermissions' indicate message signing permissions, i.e. permissions to sign certificate response messages contained in a EtsiTs103097Data, 'certIssuePermissions': this component shall be used to indicate issuing permissions, i.e. permissions to sign an enrolment credential / authorization ticket with certain permissions. as defined in (ETSI)	Officer
	The C-ITS PKI shall provide the following configuration capabilities to AT for certificate profiles: 'region' of type GeographicRegion as defined in IEEE Std 1609.2, present or absence, 'appPermissions' shall be used to indicate message signing permissions, i.e. permissions to sign a EtsiTs103097Data.	Configuration and management administrator
CRL, CTL and ECTL update	The RCA shall be capable of performing CA certificate revocation: Creation of a new CRL containing a newly revoked CA certificate and the associated updates of the CTL (creation of the new CTL without the revoked CA certificate). The RCA shall be capable of performing addition of a new CA certificate: generation of a new CTL containing the new CA certificate. The SubCA shall be capable of performing CA certificate revocation: Replacement of the CRL by a new CRL provided by the RCA containing a newly revoked CA certificate and associated updates of the CTL (creation of the new CTL without the revoked CA certificate). The SubCA shall be capable of performing addition of a new CA certificate: replacement of the CTL by the new CTL provided by the RCA containing the new CA certificate. The C-ITS PKI shall be able to download new ECTL. The C-ITS PKI shall be able to remove of an expired CA certificate from the CTL	Configuration and management administrator

Function	description	Associated user/role
Configuration of the DC	The C-ITS PKI shall allow to set up of network addresses for the CA, DC and CPOC	Configuration and management administrator
Set cryptographic algorithms	The C-ITS PKI shall allow privileged users to choose algorithms to be used for: Signature, Encryption.	Configuration and management administrator
Accept certificates whose validity cannot be determined	There can be cases where open field (e.g. permissions) or standard interpretation can lead to unknown cases for the PKI. In that case the administrator can validate manually the certificate. Only for CA certificates. The acceptance is required when a new CA has to be added to the CTL.	Officer
Approve and execute the issuance of CA certificates	Every time an official CA certificates has to be issued, the C-ITS PKI shall request an Officer to approve and execute this issuance.	Officer
Export CA request	Storage of generated CA request on parameterized media.	Officer
Perform destruction of sensitive data when no longer needed	E.g. private keys (CA privates keys cf CP sec 6.1.7), repositories (DC or CPOC repo, CP sec. 2.3, but CPOC not managed by the PKI), Records Archival (configuration files, audit logs, PKI documentation, CP sec. 5.5),	Configuration and management administrator, Officer
Perform encrypted export of private key, secret key or critical data	Private key, secret key or critical data can be encrypted and then exported in the form of an encrypted file.	Officer
Creation, deletion, management of user accounts	Users account can be created or deleted and the different account privileges can be set up according to the role	Configuration and management administrator
Verification of the C-ITS PKI secure state	Verification of the current state of the C-ITS PKI to verify that it is in a secure state (e.g. Code integrity validation regarding its signature, verification of the keys integrity, verification of the certificates validity)	Configuration and management administrator, Officer

607 4.7.3.3 Operationnal environment

Name	Description
AE.Physical_Protection	Physical security commensurate with the value of the TOE and the data it contains shall be provided by the environment. Root CA CPOC TLM uses authorized personnel to continually monitor the facility housing equipment on a 7x24x365 basis. The operational environment (e.g. physical facility) shall never be left unattended. The personnel of the operational environment shall never have access to the secure areas of root CAs or SubCAs unless authorized. Equipment and data (HSM activation data backup of key pair computer log key ceremony script certificate request ...) shall always be protected from unauthorized access. The physical security mechanisms for equipment at a minimum shall be in place to: · Monitor either manually or electronically for unauthorized intrusion at all times. · Ensure no unauthorized access to the hardware and activation data is permitted. · Ensure all removable media and paper containing sensitive plain-text information is stored in secure container. · Any individual non-authorized on permanent basis who is entering secure areas shall not be left without oversight by an authorized employee of the facilities (i.e. root CA CPOC and TLM facilities) · Ensure an access log is maintained and inspected periodically. · Provide at least 2 layers of increasing

Name	Description
	security such as perimeter building and operational room. · Require two trusted role physical access controls to both the cryptographic HSM and activation data.
AE.Trusted_Admin	TOE administrators shall follow and apply all administrator guidance in a trusted manner.
AE.Trusted_Hosts	It is assumed that the platform hosting the TOE is managed by a competent and trusted administrator and does not allow any attacker to access the hard disk when sensitive data are processed on the workstation by an authorized user. The user workstation must ensure effective protection against eavesdropping and unauthorized data transmission e.g.: correctly configured firewall up to-date antivirus software anti-spyware access to privileged accounts is protected all software security update have been installed and current version do not contain known vulnerabilities. It is assumed that there are no general-purpose computing capabilities (e.g. compilers or user applications) available on the TOE other than those services necessary for the operation administration and support of the TAE.
AE.Auditors Review Audit Logs	Audit Logs shall be reviewed in response to alerts based on irregularities and incidents within their CA systems and in addition periodically every year. Audit log is archived at least weekly. Log records related to certificate life cycles are kept at least five years after the corresponding certificate expires.
AE.HSM	The TOE environment provides a certified HSM which shall be used for: · Generating using administering and storing of private keys - Generating and using of random numbers (assessment of the random number generation function shall be part of the security evaluation and certification) - Creating backups of the private keys - Deletion of private keys. The communication channel between the TOE and the HSM is physical secured (dedicated link). The cryptographic module shall be certified with one of the following Protection Profiles (PPs) with the Assurance Level EAL-4 or higher: · PPs for HSMs: · CEN EN 419221-2: Protection profiles for TSP Cryptographic modules-- Part 2: o Cryptographic Module for CSP signing operations with backup o CEN EN 419221-4: Protection profiles for TSP Cryptographic modules-- Part 4: Cryptographic module for CSP signing operations without backup o CEN EN 419221-5: Protection profiles for TSP Cryptographic modules-- Part 5: - Cryptographic Module for Trust Services · PPs for Smartcards: o CEN EN 419211-2: Protection profiles for secure signature creation device -- Part 2: Device with key generation o CEN EN 419211-3: Protection profiles for secure signature creation device - Part 3: Device with key import
AE.Trusted_Time_Source	The runtime environment provides the TOE with exact date and time to ensure time stamp functions (audit traces generation request validity verification).
AE.Deployment	The TOE can be used to provide services to different kind of authorities. For each of those authority's type the TOE shall be correctly configured and shall only provide services corresponding to the entity e.g. a RCA should not be able to deliver ATs an AA should not respond to EC requests etc.

608

4.7.3.3.4 Users

Level 1	Level 2	Level 3
ITS-S	VCS (Vehicle C-ITS station)	NA
RCS (Roadside ITS station)		
Administrator	Configuration and management administrator	Configuration and management administrator RCA
Configuration and management administrator EA		

Level 1	Level 2	Level 3
Configuration and management administrator AA		
Auditor	Auditor RCA	
Auditor EA		
Auditor AA		
Officer	Officer RCA	
Officer SubCA		
Officer EA		
Officer AA		
Other IT entities	Manufacturer/operator servers	NA

4.7.3.3.5 Threats

The considered threats for the C-ITS PKI are illustrated in the following figure.

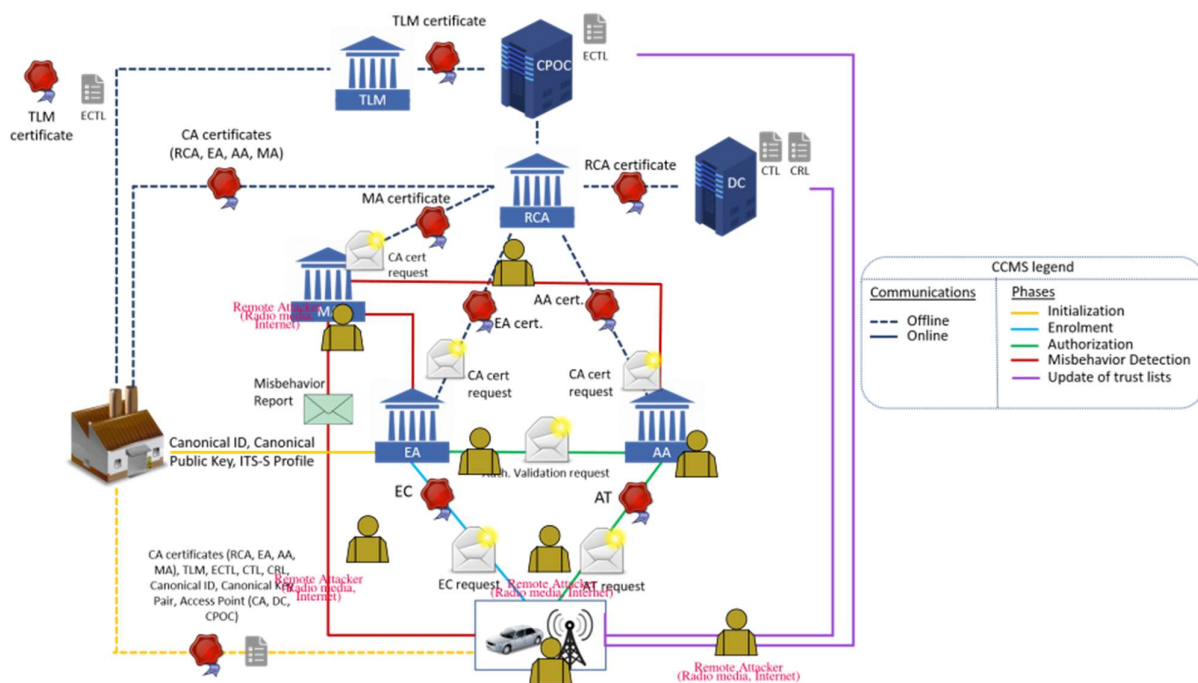


Figure 4.7.3.3.5-1: ITS_PKI_Threats_200108

Name	Description	Related assets
Remote attacker		
T.MITM	A Remote attacker may exploit interactions between the TOE and the ITS-S to expose or tamper sensitive TOE or user data.	Canonical Public Key Enrolment Credential (EC) Authorization Ticket (AT) Canonical ID Tag HMAC key CRL CTL misbehavior report.

Name	Description	Related assets
T.DOS	A Remote attacker disables communication between the TOE and the ITS station.	Software/execution of the software
T.ITS-S_Impersonation	A Remote attacker (Rogue ITS-S) sends fake requests in order to get valid EC and AT with forged attributes or fake MR in order to have targeted ITS-S to be considered misbehaving by the TAE.	EC AT MR
T.TrustListsReplay	A Remote attacker intercepts and respond to an ITS-S requesting for trust list (CRL CTL ECTL) updates by sending an old version.	CRL CTL ECTL
T.GlobalMisbehaviourReportingTampering	A Remote attacker may exploit interactions between the MA and the EA or AA in order to modify global misbehaving detection information in order to force wrong reaction either on correct ITS-S station or misbehaving stations.	MR CRL software
T.AuthorizationValidationProcessTampering	A Remote attacker may exploit interactions between the EA and AA in order to modify Authorization validation requests or responses to allow or deny inappropriate AT generation.	AT software
T.RegistrationTampering	A Remote attacker may exploit interactions between the manufacturer and the EA in order to modify or deny an ITS-S registration.	Canonical ID Canonical Public Key ITS-S Profile
Local attacker and Rogue Users		
T.PrivateKeys	A Local attacker or Rogue user disclose or tamper to the TOE secrets i.e. Data encryption key or CA private keys.	Data encryption key CA private keys
T_Logs_Tampering	A Local attacker or Rogue user tries to modify the TOE's Log File in order to hide its activities.	TSF Data
T_Logs_Discolsure	A Local attacker or Rogue user tries to gain access to the TOE's Log File in order to gain sensitive information on the TOE's security status and functions as well as other C-ITS stations.	TSF Data
T.Configuration_Tampering	A Local attacker or Rogue user tries to modify the TOE's	Certificate Policy configuration data

Name	Description	Related assets
	Certificate Policy configuration data and therefore compromise the integrity of the TOE's applications or communication security.	
T.Stored_Certificates_Tampering	A Local attacker or Rogue user tries to modify stored CA Certificates Enrolment Credential (EC) Authorization Ticket (AT) TLM certificate content and therefore compromise the confidentiality or integrity of the TOE's communications.	CA Certificates Enrolment Credential (EC) Authorization Ticket (AT) TLM certificate
All attackers		
T.Administrators_Impersonation	An attacker (Remote attacker Local attacker or Rogue user) may gain access to TOE information by impersonating an authorized user or via privilege escalation of the TOE and thus disclose or manipulate TOE assets.	Canonical Public Key CA Certificates Enrolment Credential (EC) Authorization Ticket (AT) TLM certificate Canonical ID Tag HMAC key Certificate Policy configuration CRL CTL ITS-S Profile ECTL.
T.Software_Tampering	A Local or Remote attacker tries to modify the TOE's software and therefore compromise the integrity of the TOE's applications.	Software

613 4.7.4 Machine to Machine PKI

614 *Editor's note: This section is to be done*

5 Requirements for PKI products

Editor's note: This section's structure is not stable. The content is not stable.

5.1 Auditing

- REFERENCE: REQ-5.1-01

- REQUIREMENT: The PKI shall record within each audit record at least the following information:

a) Date and time of the event, type of event, subject identity (if applicable), and the outcome (success or failure) of the event; and

b) For each audit event type, based on the auditable event definitions in TODO, the additional information specified in TODO.

- RATIONALE:

- NOTE: The audit shall not include in plaintext any private or secret keys or other critical security parameters.

- EXAMPLES:

- APPLICABILITY:

- REFERENCE: REQ-5.1-02

- REQUIREMENT: The PKI shall employ reliable time stamps.

- RATIONALE:

- NOTE:

- EXAMPLES:

- APPLICABILITY:

- REFERENCE: REQ-5.1-03

- REQUIREMENT: For audit events resulting from actions of identified users, the PKI shall be able to associate each auditable event with the identity of the user that caused the event.

- RATIONALE:

- NOTE:

- EXAMPLES:

- APPLICABILITY:

- REFERENCE: REQ-5.1-04

- REQUIREMENT: The PKI shall protect the stored audit records in the audit log from unauthorised deletion.

- RATIONALE:

- NOTE:

- EXAMPLES:

- APPLICABILITY:

- REFERENCE: REQ-5.1-05

- 649 ○ REQUIREMENT: The PKI shall be able to detect unauthorised modifications to the stored audit
650 records during the audit.
- 651 ○ RATIONALE:
- 652 ○ NOTE:
- 653 ○ EXAMPLES:
- 654 ○ APPLICABILITY:
- 655 • REFERENCE: REQ-5.1-06
- 656 ○ REQUIREMENT: The PKI shall prevent auditable events, except those taken by the auditor, if the
657 audit log is full.
- 658 ○ RATIONALE: The audit log being full should not allow for old audit records to be lost or future
659 auditable events to happen without record.
- 660 ○ NOTE:
- 661 ○ EXAMPLES:
- 662 ○ APPLICABILITY:
- 663 • REFERENCE: REQ-5.1-07
- 664 ○ REQUIREMENT: The PKI shall periodically create an audit log signing event in which it computes a
665 digital signature, keyed hash, or authentication code over the entries in the audit log. The digital
666 signature, keyed hash, or authentication code shall be computed over, at least:
 - 667 a) every entry that has been added to the audit log since the previous audit log signing event;
 - 668 b) the digital signature, keyed hash, or authentication code from the previous audit log signed event. The digital
669 signature, keyed hash, or authentication code from the audit log signing event shall be included in the audit log.
- 670 • RATIONALE: All entries of the audit log, and the order and exhaustivity of batches of entries should impact
671 authenticity checks of the audit log.
- 672 • NOTE: An audit log signing event shall be performed even if no entry was added to the audit log since the last
673 one.
- 674 • EXAMPLES:
- 675 • APPLICABILITY:
- 676 • REFERENCE: REQ-5.1-08
- 677 ○ REQUIREMENT: The specified frequency at which the audit log signing event occurs shall be
678 configurable.
- 679 ○ RATIONALE:
- 680 ○ NOTE:
- 681 ○ EXAMPLES:
- 682 ○ APPLICABILITY:

683 5.2 Secret management

- 684 TODO: (cannot apply to ALL created keys) - REFERENCE: - REQUIREMENT: The PKI shall only create key pairs or
685 symmetric keys by means of a secure cryptographic device appropriate for this use. - RATIONALE: - NOTE: -
686 EXAMPLES: - APPLICABILITY:
- 687 • REFERENCE: REQ-5.1.5.2-02

- 688 ○ REQUIREMENT: The PKI shall not persistently store private or symmetric keys in plaintext form.
- 689 ○ RATIONALE:
- 690 ○ NOTE: The PKI may store private keys in a secure cryptographic device.
- 691 ○ EXAMPLES:
- 692 ○ APPLICABILITY:
- 693 • REFERENCE: REQ-5.1.5.2-03
- 694 ○ REQUIREMENT: Public keys stored within the PKI, but not within a secure cryptographic device,
- 695 shall be protected against undetected modification through the use of digital signatures, keyed hashes,
- 696 or authentication codes. The digital signature, keyed hash, or authentication code used to protect a
- 697 public key shall be verified upon each access to the key. If verification fails, the PKI shall not:
 - 698 a) release the accessed public key to the caller; or
 - 699 b) use the accessed public key.
- 700 • RATIONALE: Unauthorized modifications of public keys stored by the PKI should not go undetected. Public
- 701 keys modified without authorization should not be considered safe for use and not be disseminated throughout
- 702 or outside the PKI.
- 703 • NOTE:
- 704 • EXAMPLES:
- 705 • APPLICABILITY:
- 706 • REFERENCE: REQ-5.1.5.2-04
- 707 ○ REQUIREMENT: The PKI shall zeroize secrets in plaintext form.
- 708 ○ RATIONALE:
- 709 ○ NOTE:
- 710 ○ EXAMPLES:
- 711 ○ APPLICABILITY: Where the PKI temporarily manipulates secrets in plaintext form.
- 712 • REFERENCE: REQ-5.1.5.2-05
- 713 ○ REQUIREMENT: The PKI shall not export private or symmetric keys in plaintext form.
- 714 ○ RATIONALE: A secret key should not be compromised if its exported form is intercepted.
- 715 ○ NOTE: The form of the exported private or symmetric key shall follow state of the art techniques
- 716 guaranteeing its confidentiality.
- 717 ○ EXAMPLES: The exported private or symmetric key may be encrypted such that only its designated
- 718 recipient may decrypt it.
- 719 ○ APPLICABILITY:

5.3 Certificate issuance

- 721 • REFERENCE: REQ-5.1.5.3-01
- 722 ○ REQUIREMENT: The certificates issued by the certificate generation service shall comply with the
- 723 X.509 standard [ITU-T X.509] or with the IETF RFC 5280 standard or with the IEEE 1609.2
- 724 standard.

- 725 ○ RATIONALE: This extends what is mandated by ETSI EN 319 411-1 and takes into account the C-
726 ITS PKI use case.
- 727 ○ NOTE:
- 728 ○ EXAMPLES:
- 729 ○ APPLICABILITY: Where the PKI has a certificate generation service.
- 730 • REFERENCE: REQ-5.1.5.3-02
- 731 ○ REQUIREMENT: The certificates issued by the certificate generation service shall be public-key
732 certificates or attribute certificates whose format complies with the X.509 standard [ITU-T X.509].
- 733 ○ RATIONALE: Public-key certificates shall use version 3 certificates since this standard requires the
734 use of certificates extensions.
- 735 ○ NOTE: At a minimum, the PKI shall ensure that:
- 736 a) the version field shall contain the integer 2;
- 737 b) the serialNumber shall be unique with respect to the issuing Certification Authority;
- 738 c) the validity field shall specify a notBefore value that does not precede the current time and a notAfter value that does
739 not precede the value specified in notBefore;
- 740 d) if the issuer field contains a null Name (e.g., a sequence of zero relative distinguished names), then the certificate
741 shall contain a critical issuerAltName extension;
- 742 e) if the subject field contains a null Name (e.g., a sequence of zero relative distinguished names), then the certificate
743 shall contain a critical subjectAltName extension;
- 744 f) the signature field and the algorithm in the subjectPublicKeyInfo field shall designate a recommended agreed
745 signature algorithm [ETSI TS 119 312].
- 746 • EXAMPLES:
- 747 • APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.
- 748 • REFERENCE: REQ-5.1.5.3-03
- 749 ○ REQUIREMENT: The PKI shall implement a certificate profile and shall ensure that issued
750 certificates are consistent with that profile.
- 751 ○ RATIONALE:
- 752 ○ NOTE:
- 753 ○ EXAMPLES:
- 754 ○ APPLICABILITY: Where the PKI has a certificate generation service.
- 755 • REFERENCE: REQ-5.1.5.3-04
- 756 ○ REQUIREMENT: The PKI shall require the Administrator to specify the set of acceptable values for
757 the following fields and extensions:
- 758 a) the authority key identifier;
- 759 b) the algorithm identifier for the subject's public/private key pair;
- 760 c) the identifier of the certificate issuer;
- 761 d) the length of time for which the certificate is valid.
- 762 • RATIONALE:
- 763 • NOTE:

- 764 • EXAMPLES:
- 765 • APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.
- 766 • REFERENCE: REQ-5.1.5.3-05
- 767 ○ REQUIREMENT: The PKI shall require the Administrator to specify the set of acceptable values for
- 768 the following fields and extensions:
- 769 a) keyUsage;
- 770 b) basicConstraints;
- 771 c) certificatePolicies.
- 772 • RATIONALE:
- 773 • NOTE:
- 774 • EXAMPLES:
- 775 • APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.
- 776 • REFERENCE: REQ-5.1.5.3-06
- 777 ○ REQUIREMENT: The PKI shall mark the following extensions as critical:
- 778 a) keyUsage;
- 779 b) basicConstraints;
- 780 c) certificatePolicies.
- 781 • RATIONALE:
- 782 • NOTE:
- 783 • EXAMPLES:
- 784 • APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.
- 785 • REFERENCE: REQ-5.1.5.3-07
- 786 ○ REQUIREMENT: The PKI shall disallow the keyUsage extension to simultaneously include values
- 787 from both of:
- 788 a) digitalSignature, contentCommitment, keyCertSign, cRLSign; and
- 789 b) keyEncipherment, dataEncipherment, keyAgreement.
- 790 • RATIONALE: The same public key may not be used for signature verification, and encryption or key
- 791 agreement.
- 792 • NOTE:
- 793 • EXAMPLES:
- 794 • APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.
- 795 • REFERENCE: REQ-5.1.5.3-08
- 796 ○ REQUIREMENT: The PKI shall verify that the prospective certificate subject possesses the private
- 797 key that corresponds to the public key in the certificate request before issuing a certificate, unless the
- 798 public/private key pair was generated by the PKI and never left the certificate issuance service.
- 799 ○ RATIONALE: A subject bringing forth his own public key should prove ownership of the public key.
- 800 The PKI may generate a key pair and associated public key, and later communicate the private key to
- 801 the correct subject in a secure manner. This may notably be done for other components of the PKI

itself needing public-key certificates. The same private key should not be owned by distinct subjects, including other services of the PKI; if the private key was generated by the PKI but already provided to the subject once, the subject can and should prove its ownership.

○ NOTE:

○ EXAMPLES:

○ APPLICABILITY: Where the PKI has a certificate generation service, issuing public-key certificates.

5.4 Certificate status

- REFERENCE: REQ-5.1.5.4-01

○ REQUIREMENT: The certificate status service shall provide certificate revocation statuses as either or both of:

a) CRLs as defined by and subject to the requirements of [ITU-T X.509]; or

b) OCSP responses to OCSP requests as defined by and subject to the requirements of [RFC 6960].

- RATIONALE:

- NOTE:

- EXAMPLES:

- APPLICABILITY: Where the PKI has a certificate status service.

- REFERENCE: REQ-5.1.5.4-02

○ REQUIREMENT: The PKI shall implement a CRL profile and shall ensure that issued CRLs are consistent with that profile.

○ RATIONALE:

○ NOTE:

○ EXAMPLES:

○ APPLICABILITY: Where the PKI has a certificate status service, issuing CRLs.

- REFERENCE: REQ-5.1.5.4-03

○ REQUIREMENT: The PKI shall require the Administrator to specify the set of acceptable values for the following fields and extensions:

a) issuer;

b) issuerAltName;

c) nextUpdate.

- RATIONALE:

- NOTE: The issuerAltName may be absent from the profile if issued certificates do not use it.

- EXAMPLES:

- APPLICABILITY: Where the PKI has a certificate status service, issuing CRLs.

- REFERENCE: REQ-5.1.5.4-04

○ REQUIREMENT: The PKI shall implement an OCSP response profile and shall ensure that issued OCSP responses are consistent with that profile.

○ RATIONALE:

- 839 ○ NOTE:
- 840 ○ EXAMPLES:
- 841 ○ APPLICABILITY: Where the PKI has a certificate status service, issuing OCSF responses.
- 842 • REFERENCE: REQ-5.1.5.4-05
- 843 ○ REQUIREMENT: The PKI shall require the Administrator to specify the set of acceptable values for
- 844 the responseType field.
- 845 ○ RATIONALE:
- 846 ○ NOTE:
- 847 ○ EXAMPLES:
- 848 ○ APPLICABILITY: Where the PKI has a certificate status service, issuing OCSF responses, not
- 849 restricted to the basic response type.
- 850 • REFERENCE: REQ-5.1.5.4-06
- 851 ○ REQUIREMENT: The PKI shall require the Administrator to specify the set of acceptable values for
- 852 the responderID field.
- 853 ○ RATIONALE:
- 854 ○ NOTE: An OCSF responder is required to be capable to emit OCSF responses of the basic type by
- 855 [RFC 6960].
- 856 ○ EXAMPLES:
- 857 ○ APPLICABILITY: Where the PKI has a certificate status service, issuing OCSF responses of the
- 858 basic response type.
- 859 • REFERENCE:
- 860 ○ REQUIREMENT:
- 861 ○ RATIONALE:
- 862 ○ NOTE:
- 863 ○ EXAMPLES:
- 864 ○ APPLICABILITY:

5.5 Certificate renewal

- 866 • REFERENCE: REQ-5.1.5.5-01
- 867 ○ REQUIREMENT: Requirement GEN-6.3.6-10 contained in ETSI EN 319 411-1 shall apply.
- 868 ○ NOTE: The term "sufficient" in the requirement means that the security is to be evaluated according
- 869 to the current state of the art.

5.6 Certificate re-key

- 871 • REFERENCE: REQ-5.1.5.6-01
- 872 ○ REQUIREMENT: In case of certificate re-key, if any certified names or attributes have changed, the
- 873 related registration information shall be recorded, after a proper verification.

5.7 Certificate modification

- REFERENCE: REQ-5.1.5.7-01
 - REQUIREMENT: In case of certificate modification, if any certified names or attributes have changed, the related registration information shall be recorded, after a proper verification.

5.8 Certificate suspension and revocation

- REFERENCE: REQ-5.1.5.8-01
 - REQUIREMENT: Once a certificate is revoked, it shall not be reinstated.
 - NOTE: Revocation is intended to be a definitive action, from which this requirement stems
- REFERENCE: REQ-5.1.5.8-02
 - REQUIREMENT: Requirements CSS-6.3.9-06, CSS-6.3.9-08, CSS-6.3.9-12 and CSS-6.3.9-13 contained in ETSI EN 319 411-1 (V1.5.1) shall apply.

5.9 Certificate status services

- REFERENCE: REQ-5.1.5.9-01
 - REQUIREMENT: Requirements CSS-6.3.10-03, CSS-6.3.10-04 and CSS-6.3.10-05 contained in ETSI EN 319 411-1 (V1.5.1) shall apply.
- REFERENCE: REQ-5.1.5.9-02
 - REQUIREMENT: If a PKI supports multiple methods to provide revocation status, the information provided by all services shall be consistent over time taking into account different delays in updating the status information for all the methods.
 - NOTE: This is aligned with requirement CSS-6.3.10-09 contained in ETSI EN 319 411-1 (V1.5.1)

6 Conformity Assessment

Editor's note: This section's structure is stable. The content is not stable.

6.1 Auditing

6.1.6 Conformity Assessment

6.1.6.1 Auditing

REFERENCE: ASS-REQ-6.1.5.1-01

- OBJECTIVE: Verify that the PKI records within each audit record the required information, and that these records do not include any secret key or other secret parameter in plaintext form.

- PREPARATION: Ability to trigger auditable events, and ability to audit events.

- ACTIVITIES:

Trigger an auditable event. Access the corresponding audit record. Verify the audit record contains at least:

- a) the date and time of the event;
- b) the type of the event;
- c) the subject identity (if applicable);
- d) the outcome of the event.

Perform the above for each audit event type, and verify that the audit record additionally contains the additional information specified in TODO.

For each information verified to be present, verify it matches the expected value given when and how the event was triggered.

For each of the generated audit record, verify that no private or symmetric key, as well as no other secret parameter is present in plaintext form.

- VERDICT: SUCCESS if all the verifications pass; else FAIL.
- EVIDENCE: The way the events were triggered and at what time, and the corresponding audit records.
- REFERENCE: ASS-REQ-6.1.5.1-02
 - OBJECTIVE: Verify that the PKI employs reliable time stamps.
 - PREPARATION: Ability to trigger auditable events, and ability to audit events. Obtain access to a trusted time stamp origin. Determine how the PKI determines its time stamps.
 - ACTIVITIES: Trigger an auditable event. Access the corresponding audit record. Verify the date and time of the event to match the trusted time stamp origin.

Repeat the above several times from different accesses to the PKI in parallel and verify the produced time stamps from the PKI to be monotonic.

If the PKI may determine its time stamps by querying time information from a source it trusts, verify that it authenticates that source messages using state of the art mechanisms.

If the PKI may increment temporary or long-term time information stored locally, verify that the time information may not be used in data issued by the PKI until it has been properly been incremented, or alternatively that the service responsible for it cannot fail.

- VERDICT: SUCCESS if all the verifications pass; else FAIL.

- 931 • EVIDENCE:
- 932 a) The way the events were triggered and at what time, and the corresponding audit records;
- 933 b) arguments relating to the authentication of a trusted source (if applicable);
- 934 c) arguments relating to the monotonicity of local time information (if applicable).
- 935 • REFERENCE: ASS-REQ-6.1.5.1-03
- 936 ○ OBJECTIVE: Verify that the PKI records within each audit record resulting from actions of identified
- 937 users the corresponding user information.
- 938 ○ PREPARATION: Ability to identify to the PKI as a given user. Ability to trigger auditable events as a
- 939 user, and ability to audit events.
- 940 ○ ACTIVITIES: Identify to the PKI as the given user. Trigger an auditable event as the given user.
- 941 Access the corresponding audit record.
- 942 Verify the audit record contains the identity of the user that caused the event. Verify this identity to match that of the
- 943 given user.
- 944 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 945 • EVIDENCE:
- 946 a) The identity of the given user used for the test;
- 947 a) the way the event was triggered and at what time, and the corresponding audit record.
- 948 • REFERENCE: ASS-REQ-6.1.5.1-04
- 949 ○ OBJECTIVE: Verify PKI protections from unauthorised deletion to be active and functional.
- 950 ○ PREPARATION: Ability to identify to the PKI as a given user, unauthorised to perform audit record
- 951 deletion. Ability to trigger auditable events as a user, and ability to audit events. Determine all actions
- 952 that may result in deletion of an audit record. Depending on this list of actions, several distinct users
- 953 with distinct authorizations may be used.
- 954 ○ ACTIVITIES: Identify to the PKI as the given user. Trigger an auditable event as the given user.
- 955 Access and copy audit records separately.
- 956 Attempt to perform all actions identified as possibly resulting in an audit record deletion; re-identifying to the PKI as
- 957 necessary.
- 958 Access audit records and verify they match the copy performed previously.
- 959 • VERDICT: SUCCESS if the verification passes; else FAIL.
- 960 • EVIDENCE:
- 961 a) The identity of the given user(s) used for the test;
- 962 b) the list of identified actions that may result in deletion of an audit records;
- 963 c) the way the actions were attempted, including the corresponding user identity;
- 964 d) the copies of existing audit records, before and after attempts.
- 965 • REFERENCE: ASS-REQ-6.1.5.1-05
- 966 ○ OBJECTIVE: Verify the PKI's ability to detect unauthorised modifications to the stored audit records
- 967 during the audit.
- 968 ○ PREPARATION: Ability to trigger auditable events as a user, and ability to audit events. Ability to
- 969 directly modify the contents of existing audit records.
- 970 ○ ACTIVITIES: Trigger an auditable event. Access and copy the corresponding audit record separately.

- 971 Directly modify the contents of the stored audit record in the PKI.
- 972 Attempt to access the audit record.
- 973 • VERDICT: SUCCESS if the last audit fails; else FAIL.
- 974 • EVIDENCE:
- 975 a) the way the event was triggered, and the corresponding audit record which was copied;
- 976 b) the way the audit record was directly modified;
- 977 c) the way the last audit was attempted, and the corresponding response from the PKI.
- 978 • REFERENCE: ASS-REQ-6.1.5.1-06
- 979 ○ OBJECTIVE: Verify the PKI's prevention of auditable events, except those taken by the auditor, if the
- 980 audit log is full.
- 981 ○ PREPARATION: Ability to trigger auditable events, and ability to audit events. The maximum size of
- 982 the audit log may be reduced.
- 983 ○ ACTIVITIES: Do not identify as an auditor to the PKI. Trigger auditable events until the audit log is
- 984 full, or nearly so.
- 985 Verify that a given additional auditable event cannot be performed.
- 986 • VERDICT: SUCCESS if the verification passes; else FAIL.
- 987 • EVIDENCE:
- 988 a) The configured maximum size of the audit log;
- 989 b) The size of the audit when full, or nearly so;
- 990 c) the way the additional event was attempted to be triggered, and the corresponding response from the PKI.
- 991 • REFERENCE: ASS-REQ-6.1.5.1-07
- 992 ○ OBJECTIVE: Verify the use of an audit log signing event by the PKI.
- 993 ○ PREPARATION: Ability to trigger auditable events, and ability to audit events.
- 994 Determine the configured frequency of the audit log signing event and date of the audit log signing event. The
- 995 frequency of the audit log signing event may be reduced; the event shall not be triggered manually.
- 996 The list of auditable events may be reduced.
- 997 Ability to verify the digital signatures, keyed hashes, or authentication codes used for the audit log signing event.
- 998 Ability to modify audit records before verifying or re-verifying their digital signatures, keyed hashes, or authentication
- 999 codes.
- 1000 • ACTIVITIES: Trigger an auditable event.
- 1001 Wait until the next audit log signing event happens.

- 1002 Verify the signature, keyed hash or authentication code over the last entries, including the audit record of the triggered
1003 event, is present in the audit log.
- 1004 Verify the signature, keyed hash or authentication code over the last entries, including the audit record of the triggered
1005 event, is correct.
- 1006 Modify the audit record of the triggered event, and verify the signature, keyed hash or authentication code to fail over
1007 the last entries, including the triggered event.
- 1008 Verify the signature, keyed hash or authentication code to fail over the last entries, including the triggered event.
- 1009 Restore the audit record of the triggered event, if necessary.
- 1010 Modify the second-to-last signature, keyed hash or authentication code.
- 1011 Verify the signature, keyed hash or authentication code to fail over the last entries, including the triggered event.
- 1012 Restore the second-to-last signature, keyed hash or authentication code, if necessary.
- 1013 Wait until the next audit log signing event happens, ensuring no auditable event happens in the meantime.
- 1014 Verify a new signature, keyed hash or authentication code, including at least the previous signature, keyed hash or
1015 authentication code, is present in the audit log.
- 1016 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1017 • EVIDENCE:
- 1018 a) The way the auditable event was triggered;
- 1019 b) the last entries of the audit log, including all the entries impacting the third-to-last audit log signing event and its
1020 signature, keyed hash or authentication code;
- 1021 c) the way the signatures, keyed hashes or authentication codes were verified, and the corresponding responses from the
1022 PKI;
- 1023 d) the way the audit record of the triggered event was modified;
- 1024 d) the way the second-to-last signature, keyed hash or authentication code was modified.
- 1025 • REFERENCE: ASS-REQ-6.1.5.1-08
- 1026 ○ OBJECTIVE: Verify the frequency of the audit log signing event by the PKI to be configurable.
- 1027 ○ PREPARATION: Ability to trigger auditable events, and ability to audit events. Ability to configure
1028 the frequency of the audit log signing event.
- 1029 ○ ACTIVITIES: Modify the frequency of the audit log signing event.
- 1030 Wait sufficiently such that 2 audit log signing events occur.
- 1031 Access audit records, and verify the time between the last 2 audit log signing events corresponds to the newly
1032 configured frequency.
- 1033 • VERDICT: SUCCESS if the verification passes; else FAIL.
- 1034 • EVIDENCE:
- 1035 a) The new frequency which was configured;
- 1036 b) the 2 last audit log signing events as they appear in the audit log, and their corresponding date and time.
- 1037 **6.1.6.2 Secret management**
- 1038 • REFERENCE: ASS-REQ-6.1.5.2-02
- 1039 ○ OBJECTIVE: Verify the PKI does not persistently store private or symmetric keys in plaintext form.
- 1040 ○ PREPARATION: Document the profiles of private and symmetric keys manipulated by the PKI, and
1041 how they are manipulated by the PKI.

- 1042 ○ ACTIVITIES: Verify that keys accessed in plaintext form are only used to perform a single operation
- 1043 once, or operations in a single batch.
- 1044 ○ VERDICT: SUCCESS if the verification passes; else FAIL.
- 1045 ○ EVIDENCE:
- 1046 a) The documentation of private and symmetric keys profiles and how these keys are manipulated.
- 1047 • REFERENCE: ASS-REQ-6.1.5.2-03
- 1048 ○ OBJECTIVE: Verify public keys stored within the PKI outside a secure cryptographic device are
- 1049 protected against undetected modification, and that public keys are released or used after a detected
- 1050 modification.
- 1051 ○ PREPARATION: Document public keys manipulated by the PKI outside a secure cryptographic
- 1052 device, and how they are manipulated by the PKI.
- 1053 Ability to directly modify such a stored public key. Ability to directly modify digital signatures, keyed hashes, or
- 1054 authentication codes associated to such stored public keys.
- 1055 Ability to request the public key (if applicable). Ability to trigger an action of the PKI making it use the public key (if
- 1056 applicable).
- 1057 • ACTIVITIES: For every public key stored within the PKI outside a secure cryptographic device:
- 1058 a) directly modify the stored public key;
- 1059 b) attempt to request the public key;
- 1060 c) verify the request fails;
- 1061 d) attempt to trigger an operation whereby the PKI makes use of the public key;
- 1062 e) verify the operation fails because of the state of the public key;
- 1063 f) restore the stored public key;
- 1064 g) directly modify the digital signature, keyed hash, or authentication code associated to the stored public key;
- 1065 h) attempt to request the public key;
- 1066 i) verify the request fails;
- 1067 j) attempt to trigger an operation whereby the PKI makes use of the public key;
- 1068 k) verify the operation fails because of the state of the public key.
- 1069 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1070 • EVIDENCE:
- 1071 a) The documentation of public keys and how they are manipulated;
- 1072 b) the way the public keys were requested, and the response from the PKI;
- 1073 c) the way operations making use of public keys were attempted to be triggered, and the response from the PKI;
- 1074 • REFERENCE: ASS-REQ-6.1.5.2-04
- 1075 ○ OBJECTIVE: Verify the public key zeroizes secrets in plaintext form.
- 1076 ○ PREPARATION: Document secrets manipulated by the PKI in plaintext form outside a secure
- 1077 cryptographic device. Access to PKI source codes.
- 1078 ○ ACTIVITIES:
- 1079 a) For every such secret, verify related source codes systematically perform its secure zeroization after the secret is
- 1080 used;

1081 b) For every zeroization method employed, identify a related secret in memory while it is used, and verify the secret to
 1082 be irrecoverable in full after zeroization.

1083 • VERDICT: SUCCESS if all the verifications pass; else FAIL.

1084 • EVIDENCE:

1085 a) The documentation of secrets and how they are manipulated;

1086 b) the documentation of zeroization methods employed.

1087 • REFERENCE: ASS-REQ-6.1.5.2-05

1088 ○ OBJECTIVE: Verify the PKI cannot export private or symmetric keys in plaintext form.

1089 ○ PREPARATION: Document how private and symmetric keys may be exported by the PKI.

1090 ○ ACTIVITIES: For each method of export, verify the secret key is not in plaintext form.

1091 ○ VERDICT: SUCCESS if all the verifications pass; else FAIL.

1092 ○ EVIDENCE: The documentation of supported export methods.

1093 6.1.6.3 Certificate issuance

1094 • REFERENCE: ASS-REQ-6.1.5.3-01

1095 ○ OBJECTIVE: Verify the certificates issued by the certificate generation service are public-key
 1096 certificates or attribute certificates whose format complies with the X.509 standard [ITU-T X.509].

1097 ○ PREPARATION: TODO

1098 ○ ACTIVITIES: TODO

1099 ○ VERDICT: TODO

1100 ○ EVIDENCE: TODO

1101 • REFERENCE: ASS-REQ-6.1.5.3-02

1102 ○ OBJECTIVE: Verify the format of public-key certificates issued by the certificate generation service
 1103 complies with the X.509 standard [ITU-T X.509].

1104 ○ PREPARATION: Document the circumstances in which the certificate generation service may issue a
 1105 certificate. Ability to request a certificate issuance for the different identified circumstances.

1106 ○ ACTIVITIES: For each way the PKI may issue a certificate:

1107 a) issue a certificate;

1108 b) verify points a,c,f of the NOTE of REQ-5.1.5.3-02;

1109 c) attempt to issue a certificate with a null Name for the issuer field, then verify the certificate contains a critical
 1110 issuerAltName extension;

1111 d) attempt to issue a certificate with a null Name for the subject field, then verify the certificate contains a critical
 1112 subjectAltName extension;

1113 • VERDICT: SUCCESS if all the verifications pass; else FAIL.

1114 • EVIDENCE:

1115 a) The documentation of certificate issuance circumstances;

1116 b) the way issuances were requested, and the responses and issued certificates from the PKI.

1117 • REFERENCE: ASS-REQ-6.1.5.3-03

- 1118 ○ OBJECTIVE: Verify the PKI implements and follows a certificate profile for issued certificates.
- 1119 ○ PREPARATION: Document the circumstances in which the certificate generation service may issue a
- 1120 certificate. Ability to request a certificate issuance for the different identified circumstances.
- 1121 Document the certificate profile implemented by the PKI.
- 1122 • ACTIVITIES: For each way the PKI may issue a certificate:
 - 1123 a) issue a certificate;
 - 1124 b) verify the certificate to match the constraints of the certificate profile;
 - 1125 c) for all constraints of the certificate profile, attempt to issue a certificate disrespecting the constraint, and verify the
 - 1126 issuance to fail.
- 1127 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1128 • EVIDENCE:
 - 1129 a) The documentation of certificate issuance circumstances;
 - 1130 b) the documentation of the certificate profile;
 - 1131 c) the way issuances were requested, and the responses and issued certificates from the PKI.
- 1132 • REFERENCE: ASS-REQ-6.1.5.3-04
 - 1133 ○ OBJECTIVE: Verify that the PKI requires the Administrator to specify the set of acceptable values
 - 1134 for the fields and extensions identified in REQ-5.1.5.3-04.
 - 1135 ○ PREPARATION: Document the circumstances in which the certificate generation service may issue a
 - 1136 public-key certificate.
- 1137 Administrator access to not-installed or reinitialised PKI, or specifically its certificate generation service and related
- 1138 configuration.
 - 1139 • ACTIVITIES: For each way the PKI may issue a public-key certificate:
 - 1140 verify that no certificate may be issued until acceptable values for the identified fields and extensions are set.
 - 1141 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
 - 1142 • EVIDENCE:
 - 1143 a) The documentation of public-key certificate issuance circumstances;
 - 1144 b) the way issuances were requested, and the responses from the PKI.
 - 1145 • REFERENCE: ASS-REQ-6.1.5.3-05
 - 1146 ○ OBJECTIVE: Verify the PKI marks the keyUsage, basicConstraints and certificatePolicies as critical
 - 1147 in issued certificates.
 - 1148 ○ PREPARATION: Document the circumstances in which the certificate generation service may issue a
 - 1149 public-key certificate. Ability to request a certificate issuance for the different identified
 - 1150 circumstances.
 - 1151 ○ ACTIVITIES: For each way the PKI may issue a public-key certificate:
 - 1152 a) issue a certificate;
 - 1153 b) verify the keyUsage, basicConstraints and certificatePolicies extensions to be marked critical;
 - 1154 c) if applicable, attempt to issue a certificate with either extension marked not critical, and verify the issuance to fail.
 - 1155 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
 - 1156 • EVIDENCE:

- 1157 a) The documentation of public-key certificate issuance circumstances;
- 1158 b) the way issuances were requested, and the responses and issued certificates from the PKI.
- 1159 • REFERENCE: ASS-REQ-6.1.5.3-06
- 1160 ○ OBJECTIVE: Verify the PKI disallows the keyUsage extension to offer both digital signature and
- 1161 encryption or key agreement capabilities.
- 1162 ○ PREPARATION: Document the circumstances in which the certificate generation service may issue a
- 1163 public-key certificate. Ability to request a certificate issuance for the different identified
- 1164 circumstances.
- 1165 ○ ACTIVITIES:
- 1166 For each way the PKI may issue a public-key certificate:
- 1167 a) issue a certificate;
- 1168 b) verify the keyUsage extension does not contain values from simultaneously:
- 1169 b.1) digitalSignature, contentCommitment, keyCertSign, cRLSign; and
- 1170 b.2) keyEncipherment, dataEncipherment, keyAgreement.
- 1171 c) if applicable, attempt to issue such a certificate and verify the issuance to fail.
- 1172 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1173 • EVIDENCE:
- 1174 a) The documentation of public-key certificate issuance circumstances;
- 1175 b) the way issuances were requested, and the responses and issued certificates from the PKI.
- 1176 • REFERENCE: ASS-REQ-6.1.5.3-07
- 1177 ○ OBJECTIVE: Verify the PKI ensures a prospective certificate subject possesses the private key that
- 1178 corresponds to the public key in the certificate request before issuing a certificate.
- 1179 • PREPARATION: Document the circumstances in which the certificate generation service may issue a public-
- 1180 key certificate.
- 1181 Ability to request a certificate issuance.
- 1182 • ACTIVITIES:
- 1183 For each way the PKI may issue a public-key certificate:
- 1184 a) attempt to issue a certificate with digital signature capabilities for a given public-key;
- 1185 b) provide an invalid signature when required;
- 1186 c) verify the issuance to fail;
- 1187 d) attempt to issue a certificate with encryption or key agreement capabilities for a given public-key;
- 1188 e) provide an invalid decryption when required;
- 1189 f) verify the issuance to fail.
- 1190 Among all the issuance attempts, verify the random value to sign or decrypt is always distinct, and their concatenation
- 1191 of high entropy.
- 1192 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1193 • EVIDENCE:
- 1194 a) The documentation of public-key certificate issuance circumstances;

1195 b) the way issuances were requested, and the responses from the PKI;

1196 c) the random values generated by the PKI.

1197 6.1.6.4 Certificate status

1198 • REFERENCE: ASS-REQ-6.1.5.4-01

1199 ○ OBJECTIVE: Verify the certificate revocation statuses to be either or both of CRLs as defined by and
1200 subject to the requirements of [ITU-T X.509],

1201 or OSCP responses as defined by and subject to the requirements of [RFC 6960].

1202 • PREPARATION: TODO

1203 • ACTIVITIES: TODO

1204 • VERDICT: TODO

1205 • EVIDENCE: TODO

1206 • REFERENCE: ASS-REQ-6.1.5.4-02

1207 ○ OBJECTIVE: Verify the PKI implements and enforces a CRL profile for issued CRLs.

1208 ○ PREPARATION: Ability to request a CRL as certificate status for a given certificate. Document the
1209 CRL profile implemented by the PKI.

1210 ○ ACTIVITIES:

1211 a) Request a CRL;

1212 b) verify the CRL to match the constraints of the CRL profile.

1213 • VERDICT: SUCCESS if all the verifications pass; else FAIL.

1214 • EVIDENCE: The way the CRL was requested, and the response and CRL from the PKI.

1215 • REFERENCE: ASS-REQ-6.1.5.4-03

1216 ○ OBJECTIVE: Verify that the PKI requires the Administrator to specify the set of acceptable values
1217 for the fields and extensions identified in REQ-5.1.5.4-03.

1218 ○ PREPARATION: Administrator access to not-installed or reinitialised PKI, or specifically its
1219 certificate status service and related configuration.

1220 ○ ACTIVITIES: Verify that no CRL may be issued until acceptable values for the issuer,
1221 issuerAltName and nextUpdate fields and extensions are set.

1222 ○ VERDICT: SUCCESS if the verifications passes; else FAIL.

1223 ○ EVIDENCE: The way CRLs were requested, and the responses from the PKI.

1224 • REFERENCE: ASS-REQ-6.1.5.4-04

1225 ○ OBJECTIVE: Verify the PKI implements and enforces an OSCP response profile for issued OSCP
1226 responses.

1227 ○ PREPARATION: Ability to request an OSCP response as certificate status for a given certificate.
1228 Document the OSCP response profile implemented by the PKI.

1229 ○ ACTIVITIES:

1230 a) Request an OSCP response;

- 1231 b) verify the OCSP response to match the constraints of the OCSP response profile.
- 1232 • VERDICT: SUCCESS if all the verifications pass; else FAIL.
- 1233 • EVIDENCE: The way the OCSP response was requested, and the response and OCSP response from the PKI.
- 1234 • REFERENCE: ASS-REQ-6.1.5.4-05
- 1235 ○ OBJECTIVE: Verify that the PKI requires the Administrator to specify the set of acceptable values
1236 for the fields and extensions identified in REQ-5.1.5.4-05.
- 1237 ○ PREPARATION: Administrator access to not-installed or reinitialised PKI, or specifically its
1238 certificate status service and related configuration.
- 1239 ○ ACTIVITIES: Verify that no OCSP response may be issued until acceptable values for the
1240 responseType and responderID fields are set.
- 1241 ○ VERDICT: SUCCESS if all the verification pass; else FAIL.
- 1242 ○ EVIDENCE: The way OCSP responses were requested, and the responses and OCSP responses from
1243 the PKI.

Annex A Mapping with essential requirements of the CRA

Table A.1: Relationship between the present document and the requirements of Regulation 2024/2847

Harmonised Standard ETSI EN 304 624 - Properties of the Product					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
(1)	Design, development, and production must ensure appropriate <u>cybersecurity</u> based on risks				
(2)(a)	No known exploitable vulnerabilities at market release				
(2)(b)	Secure-by-default configuration				
(2)(c)	Vulnerabilities can be addressed via security updates, default to automatic, with opt-out and postponement				
(2)(d)	Protection from unauthorised access via authentication and access control				
(2)(e)	Confidentiality of data in storage or transit (e.g., encryption)				
(2)(f)	Integrity of data, commands, programs, configuration; detect/report manipulation				
(2)(g)	Data minimisation — only adequate and necessary data shall be processed				
(2)(h)	Ensure availability of essential functions including resilience and <u>DoS</u> protection				
(2)(i)	Avoid degradation of other systems' availability (non-interference)				

1245

Harmonised Standard ETSI EN 304 624 - Properties of the Product					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
(2)(j)	Limit attack surfaces including external interfaces				
(2)(k)	Include appropriate exploitation mitigation techniques				
(2)(l)	Logging and internal monitoring of data/function access, with opt-out				
(2)(m)	Allow users to permanently remove data and settings securely				

Table A.2: Relationship between the present document and the requirements of Regulation 2024/2847

Harmonised Standard ETSI EN 304 624 - Vulnerability Handling Requirements					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
(1)	Identify/document vulnerabilities and components; provide SBOM				
(2)	Remediate vulnerabilities without delay; separate security updates from feature updates				
(3)	Perform regular testing and reviews of cybersecurity posture				
(4)	Disclose fixed vulnerabilities with public advisories				
(5)	Enforce coordinated vulnerability disclosure (CVD) policy				
(6)	Facilitate third-party vulnerability reporting (contact channels, process)				
(7)	Secure update delivery mechanisms				
(8)	Updates shall be timely, free of charge, and include user guidance				

Key to columns:

Requirement:

No A unique identifier for one row of the table which may be used to identify a requirement. Description A textual reference to the requirement.

Requirements of Regulation

- Identification of article(s) defining the requirement in the Regulation. Clause(s) of the present document

- 1254 • Identification of clause(s) defining the requirement in the present document unless another document is
1255 referenced explicitly. Requirement Conditionality:
- 1256 • U/C Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the
1257 manufacturer's claimed functionality of the equipment (C). Condition Explains the conditions when the
1258 requirement is or is not applicable for a requirement which is classified "conditional".
- 1259 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list
1260 published in the Official Journal of the European Union. Users of the present document should consult frequently the
1261 latest list published in the Official Journal of the European Union.
- 1262 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

1263 **Annex B Mappings**

1264 **B.1 Mapping of technical security requirements and assessment**
1265 **requirements**

1266 **B.2 Mapping of technical security requirements and risks factors**

1267 **B.3 Other relevant mappings, as appropriate**

1268 Annex C Risk acceptance criteria and risk management
1269 methodology (informative) (PT1 6.3)

1270 C.1 Risk acceptance + risk management methodology

1271 C.1.1 Risks levels calculation

Impact

Impact	Description
Low	Negligible impact on organisation
Medium	Significant impact on organisation, but negligible impact on sector
High	Severe impact on organisation and significant impact on sector

NOTE: The impact of any personal data compromise is at least Medium.

1272

1273 Figure C.1.1-1: Impact scale

Likelihood

Likelihood	Description
Low	Unlikely to succeed
Medium	Could succeed
High	Likely to succeed
N/A	Does not apply for given use case

1274

1275 Figure C.1.1-2: Likelihood scale

Risk

		Impact		
		Low	Medium	High
Likelihood	Low	Low	Low	Medium
	Medium	Low	Medium	High
	High	Medium	High	High

1276

1277 Figure C.1.1-4: Risk calculation matrix

1278 C.1.2 Likelihood risk factors

Deployment

Risk factor	Description
DEP-2	Consumer use or non-critical use in enterprises
DEP-1	Critical use in enterprises (non-NIS2)
DEP-0	Critical use in enterprises (NIS2) or public PKI use

1279

1280 Figure C.1.2-1: Risk factor dep

Network security

Risk factor	Description
NET-2	Enhanced network and physical security with continuous monitoring (EN 319 401 or stronger)
NET-1	Standard enterprise network and physical security
NET-0	Limited network or physical security

1281

1282 Figure C.1.2-2: Risk factor net

User expertise

Risk factor	Description
USR-2	Skilled users with relevant experience and regular training (EN 319 401 or stronger)
USR-1	Standard enterprise users with one-off or infrequent training
USR-0	Unskilled users

1283

1284 Figure C.1.2-3: Risk factor user

Operational security

Risk factor	Description
OPS-2	Enhanced policies and procedures with strict compliance regime (EN 319 401 or better)
OPS-1	Standard enterprise policies and procedures with moderate compliance regime.
OPS-0	Limited policies and procedures.

1285

1286 **Figure C.1.2-4: Risk factor ops**

Interface exposure

Risk factor	Description
INT-2	Local interfaces only
INT-1	Remote interfaces accessible from enterprise network
INT-0	Remote interfaces accessible from public networks

1287

1288 **Figure C.1.2-5: Risk factor int**

C.1.3 Impact risk factors

1290 **Figure C.1.3-1: Risk factor ava**

Figure C.1.3-1: Risk factor ava

Integrity		Assets classification by use cases			
Risk Factor	Description	Ent. / Private PKI	Critical sector Private /Ent. PKI	Public CA PKI	C-ITS
INT-2	The modification of the asset is not critical and does not compromise the trust provided by the PKI.	REG01: Subscriber data GEN02: Subject key data STA01: Certificate status data SYS03: Event log data SYS13: Event log management function	SYS03: Event log data SYS13: Event log management function		TBD
INT-1	The modification of the asset is partially critical and implies partial compromise of the trust provide by the PKI.	SYS01: System configuration data SYS02: User account data REG02: Certificate request DIS01: Certificate store data	REG01: Subscriber data GEN02: Subject key data STA01: Certificate status data	REG01: Subscriber data SYS03: Event log data SYS13: Event log management function	TBD
INT-0	The modification of the asset is critical and does compromise entirely the trust provide by the PKI.	GEN01: CA key data REV01: Revocation request	SYS01: System configuration data SYS02: User account data REG02: Certificate request GEN01: CA key data DIS01: Certificate store data REV01: Revocation request	SYS01: System configuration data SYS02: User account data REG02: Certificate request GEN01: CA key data GEN02: Subject key data DIS01: Certificate store data REV01: Revocation request STA01: Certificate status data	TBD

Figure C.1.3-2: Risk factor in

Confidentiality		Assets classification by use cases			
Risk Factor	Description	Ent. / Private PKI	Critical sector Private /Ent. PKI	Public CA PKI	C-ITS
CON-2	The disclosure of the asset is not critical and does not compromise the trust provide by the PKI.	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data REG01: Subscriber data STA01: Certificate status data	REG01: Subscriber data STA01: Certificate status data		TBD
CON-1	The disclosure of the asset is partially critical and implies partial compromise of the trust provide by the PKI.	SYS01: System configuration data SYS02: User account data REG02: Certificate request REG12: Certificate request management function GEN11: Key management function DIS11: Certificate store management function REV11: Revocation management function	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data DIS11: Certificate store management function		TBD
CON-0	The disclosure of the asset is critical and does compromise entirely the trust provide by the PKI.	GEN01: CA key data GEN02: Subject key data GEN12: Certificate generation function REV11: Revocation management function	SYS01: System configuration data SYS02: User account data REG02: Certificate request GEN01: CA key data GEN02: Subject key data REG12: Certificate request management function GEN11: Key management function GEN12: Certificate generation function REV11: Revocation management function	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data SYS01: System configuration data SYS02: User account data REG01: Subscriber data REG02: Certificate request STA01: Certificate status data GEN01: CA key data GEN02: Subject key data REG12: Certificate request management function GEN11: Key management function GEN12: Certificate generation function DIS11: Certificate store management function REV11: Revocation management function	TBD

Figure C.1.3-3: Risk factor conf

Traceability		Assets classification by use cases			
Risk Factor	Description	Ent. / Private PKI	Critical sector Private /Ent. PKI	Public CA PKI	C-ITS
TRA-2	The lack of Traceability of the events about the asset is not critical and does not compromise the trust provide by the PKI if forensic is needed.	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data REG01: Subscriber data	REG01: Subscriber data		TBD
TRA-1	The lack of Traceability of the events about the asset is severe and compromise the trust provide by the PKI if forensic is needed.	SYS01: System configuration data SYS02: User account data REG02: Certificate request REG12: Certificate request management function GEN11: Key management function DIS11: Certificate store management function REV11: Revocation management function	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data DIS11: Certificate store management function		TBD
TRA-0	The lack of Traceability of the events about the asset is impossible and compromise the trust provide by the PKI if forensic is needed.	GEN01: CA key data GEN02: Subject key data GEN12: Certificate generation function REV11: Revocation management function	SYS01: System configuration data SYS02: User account data REG02: Certificate request GEN01: CA key data GEN02: Subject key data REG12: Certificate request management function GEN11: Key management function GEN12: Certificate generation function REV11: Revocation management function	SYS03: Event log data SYS13: Event log management function DIS01: Certificate store data SYS01: System configuration data SYS02: User account data REG01: Subscriber data REG02: Certificate request STA01: Certificate status data GEN01: CA key data GEN02: Subject key data REG12: Certificate request management function GEN11: Key management function GEN12: Certificate generation function DIS11: Certificate store management function REV11: Revocation management function	TBD

Figure C.1.3-4: Risk factor tra

C.1.4 Risk acceptance threshold

Risk threshold

Risk	Description
Low	No mitigations required
Medium	Mitigations required
High	Enhanced mitigations required

1299

1300 **Figure C.1.4-1: Risk acceptance threshold**

Interface exposure

Risk factor	Description
INT-2	Local interfaces only
INT-1	Remote interfaces accessible from enterprise network
INT-0	Remote interfaces accessible from public networks

1301

1302 **Figure C.1.4-2: Risk factor int**

1303 C.2 Risk Assessment

1304 C.2.1 ID Asset

1305 C.2.2 ID Threat

1306 C.2.3 Estimate Risks (Risk factors)

1307 C.2.4 Evaluate Risks

Annex: Bibliography

1309

Annex : Change history

Date	Version	Information about changes
<Month year>	<#>	<Changes made are listed in this cell>

1310

History

1311

+-----+ |Document History |

1312

+:=====+:=====+:=====+ |Version |Date |Milestone | +-----

1313

+-----+-----+ |<Month year> |<#> |<Changes made> | +-----+-----

1314

+ ||| | +-----+-----+ ||| | +-----+-----+ +